DuocUC | ESCUELA DE INFORMÁTICA Y TELECOMUNICACIONES

CUIDARTE+

**EVALUACIÓN PARCIAL N° 3**

# Verificación de calidad, seguridad y cumplimiento normativo

Informe de seguridad y calidad en el desarrollo de software

*Caso B: Sistema de exámenes médicos Cuidarte+*

**Asignatura**
ISY1102 · Seguridad y Calidad en el Desarrollo de Software

**Carrera:** Ingeniería en Informática
**Sección:** 001V
**Sede:** Puente Alto
**Docente:** Jose Sergio Collio Huennun
**Fecha:** Octubre de 2026

**Integrantes**
Ari Araya
Nicolás Barra
Giannina Guerrero
Skarlett Tropan

# ÍNDICE

**Siglas y abreviaturas** ..... **3**
**1. Introducción** ..... **4**
1.1 Contexto del software ..... 4
1.2 Propósito del plan y de este informe ..... 4
1.3 Objetivos ..... 4
1.4 Alcance ..... 5
1.5 Estructura del informe ..... 5
**2. Criterios de calidad** ..... **5**
2.1 Calidad del producto ..... 6
2.2 Seguridad ..... 6
2.3 Cumplimiento normativo ..... 7
**3. Plan de pruebas** ..... **7**
3.1 Estrategia de pruebas ..... 7
3.2 Tipos de prueba ..... 9
3.3 Criterios de aceptación ..... 10
3.4 Herramientas utilizadas ..... 11
**4. Diseño de casos de prueba** ..... **14**
4.1 Matriz de trazabilidad ..... 14
4.2 Catálogo de casos ..... 16
4.3 Casos detallados ..... 17
**5. Ejecución de pruebas** ..... **24**
5.1 Resumen de ejecución ..... 24
5.2 Detalle de ejecución de casos ..... 26
5.3 Criticidad de incidentes ..... 36
5.4 Análisis estático con SonarQube ..... 38
**6. Análisis ético y normativo de los resultados** ..... **46**
6.1 Enfoque ..... 46
6.2 Marco normativo aplicable ..... 46
6.3 Tensión entre el ERS y la ley ..... 48
6.4 Hallazgos y deber legal afectado ..... 48
6.5 Lectura ética ..... 50
6.6 Dictamen ..... 50
6.7 Recomendaciones ..... 51
**7. Conclusiones** ..... **53**
**8. Referencias** ..... **54**
**Anexo A. Correcciones respecto de la EV1** ..... **55**
**Anexo B. Evidencias de la EV1 y del ciclo 2** ..... **55**

## Siglas y abreviaturas

| Sigla | Significado |
|---|---|
| API | Interfaz de programación de aplicaciones |
| BD | Base de datos |
| CORS | Cross-Origin Resource Sharing, intercambio de recursos entre orígenes |
| CP | Caso de prueba |
| CRUD | Crear, leer, actualizar y eliminar |
| CSIRT | Equipo de respuesta ante incidentes de seguridad informática |
| CSP | Content Security Policy, política de seguridad de contenido |
| DAST | Pruebas dinámicas de seguridad de aplicaciones |
| DFL | Decreto con fuerza de ley |
| DS | Decreto supremo |
| ERS | Especificación de requerimientos de software |
| HSTS | HTTP Strict Transport Security |
| HTTP / HTTPS | Protocolo de transferencia de hipertexto / versión segura sobre TLS |
| INC | Incidente registrado en la ejecución |
| JWT | JSON Web Token |
| MINSAL | Ministerio de Salud |
| MQR | Multi-Quality Rule, modo de clasificación de SonarQube |
| NFR | Requisito no funcional del ERS |
| OC | Observación de cumplimiento |
| OWASP | Open Worldwide Application Security Project |
| P0 a P4 | Niveles de prioridad por riesgo (sección 3.1) |
| QA | Aseguramiento de la calidad |
| RB | Regla de negocio del ERS |
| REST | Estilo de arquitectura para API sobre HTTP |
| RF | Requisito funcional del ERS |
| RUT | Rol Único Tributario |
| SPA | Aplicación de una sola página |
| SQL | Lenguaje de consulta estructurado |
| TLS | Transport Layer Security, seguridad de la capa de transporte |
| UI | Interfaz de usuario |
| WCAG | Pautas de accesibilidad para el contenido web |
| XSS | Cross-Site Scripting |
| ZAP | Zed Attack Proxy, escáner dinámico de seguridad web |

# 1. Introducción

## 1.1 Contexto del software

Cuidarte+ es una plataforma web para centros de salud desarrollada por CreaLab SpA y corresponde al Caso B de la asignatura. Permite que los médicos registren pacientes y exámenes, que los pacientes revisen y descarguen sus documentos clínicos y que los administradores gestionen usuarios y revisen la auditoría. Está construida como una aplicación de una sola página (SPA) en React que consume una interfaz de programación de aplicaciones (API) REST en Express sobre una base de datos PostgreSQL. Para esta evaluación se ejecuta en contenedores Docker en los equipos del grupo: el frontend en el puerto 3333, la API en el 4444 (con la documentación Swagger en /docs) y la base de datos en el 15442.

El sistema trata datos de salud, que la legislación chilena califica como datos sensibles, y su público incluye personas mayores. Por eso un defecto en Cuidarte+ no queda solo en el plano técnico: puede afectar la confidencialidad de la ficha clínica, la continuidad de la atención y la responsabilidad legal del centro que lo utilice.

## 1.2 Propósito del plan y de este informe

En la primera evaluación parcial (EV1) diseñamos el plan de pruebas y seis casos representativos. Este informe continúa ese trabajo con tres cambios. Primero, la cobertura pasa de 14 a los 40 códigos de la especificación de requerimientos de software del Caso B (ERS B), cada uno con su caso de prueba. Segundo, los casos se ejecutan en el ambiente Docker y se registran con evidencia, resultado e incidentes clasificados por criticidad. Tercero, el análisis normativo incorpora la normativa sanitaria que faltaba en la EV1 (derechos de los pacientes, ficha clínica y atención de urgencia) y separa las normas vigentes de las que entran en vigencia más adelante. Estos ajustes responden a la retroalimentación que recibimos del docente sobre la EV1, y su detalle está en el Anexo A.

Las pruebas buscan asegurar tres cosas antes de un paso a producción: que el sistema hace lo que el ERS describe, que lo hace de forma segura con los datos clínicos y que permite al centro de salud cumplir la ley que lo regula.

## 1.3 Objetivos

**Objetivo general.** Verificar si Cuidarte+ cumple los requisitos funcionales, no funcionales y reglas de negocio del ERS B, junto con las exigencias legales que aplican a un sistema que gestiona información clínica, para emitir un dictamen fundado sobre su aptitud para producción.

**Objetivos específicos.** Para lograrlo nos planteamos los siguientes objetivos específicos:

1. Asociar cada uno de los 40 códigos del ERS B a un caso de prueba con tipo, riesgo y responsable definidos.
2. Ejecutar los casos en el ambiente Docker y registrar resultado, evidencia, fecha y responsable.
3. Clasificar los incidentes encontrados según la escala de criticidad de la sección 5.3.
4. Contrastar los resultados del análisis estático (SonarQube) y de las pruebas dinámicas con la normativa de la sección 6.
5. Proponer recomendaciones priorizadas y un dictamen de certificación.

### 1.4 Alcance

Quedan dentro del alcance todos los módulos del ERS B: autenticación y sesión, registro de usuarios, gestión de pacientes, exámenes y documentos, visualización por parte del paciente, auditoría y administración de usuarios y roles, además de los atributos de seguridad, rendimiento, usabilidad, disponibilidad y compatibilidad. Las pruebas se hacen solo sobre la instalación local en Docker y con datos sintéticos. Quedan fuera un pentest certificado por terceros, la certificación formal WCAG, una auditoría legal externa y la medición de disponibilidad durante un mes completo; para NFR-DIS-1 se revisa la configuración y la documentación, no el uptime real.

El ERS B conserva algunos restos del Caso A: el glosario define Atlas y el rol Editor, la sección 2.3 indica que cada usuario debe pertenecer a una o más empresas, RF-5.1 menciona clientes y contratos, y NFR-SEG-1 escribe TSL en lugar de TLS. En este informe esos requisitos se interpretan sobre las entidades reales de Cuidarte+ (pacientes, exámenes, documentos y usuarios) y se escribe TLS.

### 1.5 Estructura del informe

El informe se organiza en siete secciones y dos anexos. La sección 2 define los criterios de calidad, seguridad y cumplimiento; la sección 3 presenta el plan de pruebas (estrategia, tipos de prueba, criterios de aceptación y herramientas); la sección 4 contiene la matriz de trazabilidad y el diseño de los casos; la sección 5 muestra la ejecución, con el resumen, el detalle por caso, la criticidad de los incidentes y el análisis estático; la sección 6 desarrolla el análisis ético y normativo de los resultados, y la sección 7 cierra con las conclusiones. Al final se incluyen las correcciones respecto de la EV1 (Anexo A) y la lista de evidencias de la EV1 y del ciclo 2 (Anexo B).

## 2. Criterios de calidad

Los criterios de esta sección son el estándar contra el que se evalúa Cuidarte+. Provienen de tres fuentes: el modelo de calidad ISO/IEC 25010, los requisitos no funcionales del ERS

B y la normativa chilena que regula el tratamiento de datos de salud. Cada criterio se asocia a los códigos del ERS que lo sustentan y al caso de prueba que lo verifica.

## 2.1 Calidad del producto

**Tabla 1. Criterios de calidad del producto (ISO/IEC 25010)**

| Atributo | Criterio para Cuidarte+ | ERS | Casos |
|---|---|---|---|
| Usabilidad | Tipografía legible, contraste adecuado y controles grandes para personas mayores; flujos claros de registro y consulta; mensajes de error comprensibles | NFR-USAB-1 a 4 | CP-06, CP-20 |
| Rendimiento | CRUD simple bajo 300 ms (p95) con carga normal; página principal bajo 2 s en conexión móvil promedio; 200 usuarios concurrentes | NFR-PERF-1 a 3 | CP-05, CP-19 |
| Estabilidad y confiabilidad | Los flujos críticos responden sin errores 5xx con carga normal; los datos clínicos no se pierden ni se alteran entre operaciones | RF-3, RF-4, NFR-PERF-3 | CP-05, CP-11, CP-13, CP-19 |
| Disponibilidad | Objetivo de 99,5 % mensual y mantenimiento con ventana definida y migración segura de datos | NFR-DIS-1, NFR-DIS-2 | CP-21 |
| Mantenibilidad | Validación en el servidor, endpoints documentados en Swagger y código sin defectos bloqueantes en el análisis estático | ERS §3.1.2 | CP-16, CP-17 |
| Compatibilidad | Dos últimas versiones de Chrome, Firefox, Safari y Edge; diseño responsivo en móvil y tablet | NFR-COMPAT-1, 2 | CP-06, CP-22 |

## 2.2 Seguridad

La seguridad se trata como un requisito verificable. Cada criterio del ERS se traduce en una condición que se puede observar en la respuesta de la API, en la base de datos o en la configuración del despliegue, y no solo en la interfaz.

**Tabla 2. Criterios de seguridad**

| Código | Criterio | Qué se verifica | Casos |
|---|---|---|---|
| NFR-SEG-1 | TLS obligatorio | El tráfico HTTP se rechaza o se redirige a HTTPS en frontend y API | CP-14 |
| NFR-SEG-2 | Hash seguro de contraseñas (bcrypt) | Las contraseñas no se guardan ni se comparan en texto plano | CP-01, CP-15 |
| NFR-SEG-3 | Cifrado en reposo | Datos clínicos y documentos protegidos en la base de datos y en el almacenamiento | CP-16 |
| NFR-SEG-4 | Control de acceso por rol en el backend | El paciente solo lee; el administrador gestiona; el médico opera según RB-3 | CP-04, CP-08 |
| NFR-SEG-5 | Protección contra CSRF, XSS e inyección SQL | Entradas validadas y saneadas; cargas maliciosas rechazadas | CP-04 |
| NFR-SEG-6 | Gestión de log segura | Eventos relevantes registrados sin secretos; errores sin detalles internos | CP-17 |
| NFR-SEG-7 | Respaldo y recuperación | Respaldo definido y restauración probada | CP-18 |

| Código | Criterio | Qué se verifica | Casos |
|---|---|---|---|
| NFR-SEG-8 | Cumplimiento de protección de datos | Acceso restringido, trazabilidad y uso de datos acotado a la finalidad | CP-23 (con CP-03, CP-04) |
| NFR-SEG-9 | Sesión con JWT | Token de vigencia acotada, cierre de sesión y revocación | CP-01, CP-07 |

Las reglas de negocio completan estos criterios: el paciente solo tiene permisos de lectura sobre su información (RB-1), el administrador tiene acceso completo (RB-2) y el médico puede ver la información clínica de cualquier paciente registrado (RB-3). Esta última regla presenta una tensión con la Ley 20.584 que se analiza en la sección 6.3.

### 2.3 Cumplimiento normativo

La normativa se desarrolla en la sección 6. Aquí se resume la relación entre los criterios transversales, los códigos del ERS y la norma que los respalda. A diferencia de la EV1, la base del caso es la normativa sanitaria (Ley 20.584 y Decreto Supremo N° 41 de 2012 del Ministerio de Salud, MINSAL (en adelante, DS 41)), y la Ley 21.719 se cita como norma de vigencia futura (1 de diciembre de 2026).

**Tabla 3. Criterio, requerimiento y norma**

| Criterio transversal | Códigos ERS | Norma de respaldo |
|---|---|---|
| Confidencialidad de la ficha clínica | NFR-SEG-3, NFR-SEG-4, RB-1 | Ley 20.584 art. 13; DS 41 art. 9; Ley 19.628 art. 11 |
| Integridad y autenticidad de los documentos | RF-4.3, RF-4.4, NFR-SEG-3 | Ley 20.584 art. 12; DS 41 art. 8 |
| Trazabilidad de accesos y cambios | RF-5.1, NFR-SEG-6 | DS 41 art. 9; Ley 21.663 art. 9 |
| Autenticación y sesión | RF-1.1, RF-1.2, NFR-SEG-2, NFR-SEG-9 | Ley 19.628 art. 11; NCh-ISO 27002 como referencia técnica |
| Disponibilidad y acceso oportuno | NFR-DIS-1, NFR-PERF-1 a 3 | Ley 20.584 arts. 10, 13 y 15 b); DS 41 art. 8 |
| Conservación de la información clínica | RF-3.3, RF-2.7 | Ley 20.584 art. 13 (15 años); DS 41 arts. 11 y 12 |
| Accesibilidad para personas mayores | NFR-USAB-1 a 4, NFR-COMPAT-2 | Ley 20.584 arts. 5 a) y 5° bis; Manual de Accesibilidad Web |
| Licencias de dependencias | Stack tecnológico (ERS §3.1.2) | Ley 17.336 arts. 78 y 79 |
| Protección de datos (vigencia futura) | NFR-SEG-3, NFR-SEG-7, NFR-SEG-8 | Ley 21.719, vigente desde el 1 dic 2026 |

## 3. Plan de pruebas

### 3.1 Estrategia de pruebas

#### *Enfoque*

Usamos un enfoque mixto. En el plan, la automatización cubría lo que conviene repetir o medir con precisión, es decir, los flujos principales con Selenium, la carga y el tiempo de

respuesta con JMeter, el análisis dinámico con OWASP ZAP y Nikto, la búsqueda de inyección SQL con SQLMap y el análisis estático con SonarQube. En la ejecución se usaron SonarQube, OWASP ZAP con sesión, SQLMap, John the Ripper, JMeter y Lighthouse. El 27 de octubre de 2026 se ejecutó con Selenium una suite de 11 pruebas de interfaz, organizada con pytest y Page Objects, que recorrió login, logout, pacientes, exámenes, acceso por rol y Mis Resultados en CP-01, 02, 07, 08, 10, 11 y 12. Las 11 pasaron. Los casos negativos y el control de acceso en la API se verificaron con Postman y de forma manual. Burp Suite y Nikto no se usaron, y en su lugar las peticiones y las cabeceras se revisaron con Swagger y curl. Dejamos en manual lo que necesita criterio humano, como la usabilidad con personas mayores, la revisión de mensajes de error y las verificaciones de configuración (TLS, cifrado y respaldo).

En un sistema clínico la interfaz no basta como evidencia. Un caso de control de acceso se verifica en la respuesta de la API y en la tabla de auditoría, no solo en lo que muestra la pantalla. Por eso varios casos funcionales incluyen también un paso de API con Postman o Swagger.

### *Etapas del proceso*

La ejecución se organiza en cinco etapas. Como la fecha de la evaluación (D) no estaba publicada al momento de planificar, el cronograma se expresa en días antes de D.

**Tabla 4. Etapas de la ejecución**

| Etapa | Qué se hace | Cuándo | Responsable | Termina cuando |
|---|---|---|---|---|
| 1. Preparación | Docker en los cuatro equipos, cuentas de prueba sintéticas, SonarQube instalado | D−13 | Ari (Skarlett en SonarQube) | Los tres contenedores responden y /docs abre |
| 2. Diseño | Matriz 40/40, fichas de casos y revisión cruzada | D−12 a D−9 | Giannina (matriz), Nicolás (fichas) | Ningún código del ERS sin caso |
| 3. Ciclo 1, humo | Login de los tres roles, inicio, listado de pacientes y consulta de un examen | D−8 | Nicolás | La ruta crítica funciona o queda como Bloqueado |
| 4. Ciclo 2, ejecución completa | CP-01 a CP-23, DAST autenticado, JMeter con y sin el retraso de 5 s, SonarQube | D−8 a D−6 | Nicolás, Skarlett y Ari | Registro completo con fecha, ejecutor y evidencia |
| 5. Regresión y cierre | Reejecución de casos corregidos, clasificación de incidentes, dictamen | D−5 a D−4 | Ari (criticidad), Giannina (dictamen) | Cada incidente con severidad y evidencia; dictamen escrito |

### *Priorización*

Mantenemos la priorización por riesgo de la EV1. P0 agrupa autenticación, control de acceso y documentos clínicos, donde una falla expone datos de salud. P1 cubre auditoría, registros y respaldo, que son la evidencia que el centro necesita ante un incidente. P2 es el CRUD clínico, núcleo del negocio. P3 corresponde a rendimiento y disponibilidad, que tienen umbrales numéricos en el ERS, y P4 a usabilidad y compatibilidad. Si falta tiempo, se

ejecuta primero todo P0 y P1; un caso P3 o P4 sin ejecutar se informa como No ejecutado y nunca como aprobado.

#### *Criterios de entrada*

La ejecución formal comienza cuando el ambiente Docker funciona con los tres contenedores en el equipo de quien ejecuta, existen cuentas de prueba para administrador, médico y paciente con datos sintéticos, la matriz tiene los 40 códigos con caso asignado y cada caso que se va a ejecutar tiene resultado esperado y criterio de aceptación escritos.

#### *Criterios de salida*

El ciclo termina cuando todos los casos P0 y P1 tienen resultado registrado, cada falla tiene su incidente con severidad y evidencia legible, la matriz muestra los 40 códigos con estado de ejecución y el resumen de la sección 5.1 cuadra con el detalle de la sección 5.2. Terminar el ciclo no significa aprobar el sistema: si queda un incidente crítico abierto, el ciclo se cierra igual, pero el dictamen es No certificado.

#### *Suspensión y reanudación*

Si el ciclo de humo falla en el login o en la carga de la página de inicio, la ejecución se suspende y los casos dependientes se registran como Bloqueado con su causa. Se reanuda cuando el ambiente vuelve a responder; los casos ya ejecutados no se repiten, salvo que el cambio afecte su resultado.

### 3.2 Tipos de prueba

Las pruebas funcionales responden a la pregunta de si el sistema hace lo que debe hacer, y se derivan de RF-1 a RF-5 y de las reglas de negocio. Las no funcionales evalúan cómo lo hace: si es seguro, rápido, usable y compatible, y se derivan de los NFR. En Cuidarte+ ninguna de las dos reemplaza a la otra. Un flujo que funciona pero que entrega datos clínicos a un rol no autorizado es, además de un defecto, un incumplimiento de la Ley 20.584.

**Tabla 5. Tipos de prueba aplicados**

| Tipo | Propósito en Cuidarte+ | Requisitos | Casos |
|---|---|---|---|
| Funcional | Verificar los flujos de negocio por rol: login, pacientes, exámenes, documentos y administración de usuarios | RF-1 a RF-4, RB-2, RB-3 | CP-01, 02, 08 a 12 |
| Integración y API | Validar los contratos entre React, Express y PostgreSQL: códigos HTTP, persistencia y almacenamiento de documentos | RF-4.4, RF-5.1, ERS §3.1.2 | CP-03, CP-13 |
| Seguridad dinámica | Detectar fallas de control de acceso, sesión, inyección y configuración con el sistema en ejecución | NFR-SEG-2, 4, 5, 9, RB-1 | CP-04, 07, 15 |

| Tipo | Propósito en Cuidarte+ | Requisitos | Casos |
|---|---|---|---|
| Seguridad estática | Revisar el código fuente sin ejecutarlo para encontrar vulnerabilidades, secretos y defectos de calidad | NFR-SEG-3, NFR-SEG-6 | CP-16, CP-17 |
| Configuración y cumplimiento | Comprobar TLS, cifrado, respaldo, disponibilidad y la lista de exigencias legales | NFR-SEG-1, 7, 8, NFR-DIS-1, 2 | CP-14, 18, 21, 23 |
| Rendimiento y carga | Medir tiempos de respuesta y concurrencia frente a los umbrales del ERS | NFR-PERF-1 a 3, RF-4.2 | CP-05, CP-13, CP-19 |
| Usabilidad y accesibilidad | Evaluar el uso por personas mayores, la claridad de los flujos y los mensajes | NFR-USAB-1 a 4 | CP-06, CP-20 |
| Compatibilidad | Verificar navegadores y comportamiento responsivo | NFR-COMPAT-1, 2 | CP-06, CP-22 |
| Humo y regresión | Confirmar la estabilidad mínima antes de cada ciclo y que una corrección no rompe lo ya aprobado | RF críticos | Ciclo 1 y etapa 5 |

Priorizamos seguridad, auditoría y usabilidad porque Cuidarte+ maneja datos sensibles de salud y está orientado a personas mayores. El rendimiento se incluye porque el ERS fija umbrales medibles y porque el acceso oportuno a un examen tiene relevancia clínica, por ejemplo durante una urgencia. La combinación de análisis estático y dinámico se justifica porque cada uno detecta cosas distintas: SonarQube encuentra un secreto escrito en el código aunque nadie lo use, y ZAP encuentra una cabecera de seguridad faltante que no se ve en el código.

### 3.3 Criterios de aceptación

Estos criterios se aplican a todos los casos. Un caso puede tener un criterio propio en su ficha, pero nunca uno más débil que el general.

**Criterio general.** Un caso se marca como Aprobado solo si el resultado observado coincide con el esperado, se respeta la regla de negocio que corresponde (RB-1, RB-2 o RB-3), ningún dato clínico queda visible para un rol no autorizado y existe evidencia legible. Si aparece un problema de seguridad o de cumplimiento, el caso se marca como Fallido aunque la pantalla muestre un comportamiento aparentemente correcto.

**Tabla 6. Estados de resultado**

| Estado | Cuándo se usa |
|---|---|
| Aprobado | Se cumplen el criterio general y el criterio propio del caso |
| Fallido | El resultado difiere del esperado o se detecta un problema de seguridad o cumplimiento. Requiere incidente con severidad |
| Parcial | Una parte del caso se cumple y otra no se pudo verificar. No se cuenta como aprobado ni como fallido, y se anota qué parte quedó pendiente |
| Bloqueado | El caso no se puede ejecutar por una causa externa (ambiente caído o dependencia de un caso fallido). Se anota la causa |
| No ejecutado | El caso no alcanzó a ejecutarse en el ciclo. No cuenta como cobertura de ejecución |

**Funcionales.** Las operaciones CRUD deben funcionar y validar los datos en el servidor (ERS §3.1.2). El login correcto entrega un JSON Web Token (JWT) y el cierre de sesión debe invalidarlo (RF-1). Las eliminaciones de exámenes y documentos deben pedir confirmación y ser lógicas (RF-3). La subida y la descarga de documentos no deben superar 10 segundos (RF-4), y cada acción crítica, incluida la descarga, debe generar un registro de auditoría (RF-5).

**No funcionales.** En seguridad, la auditoría con lista de verificación y las pruebas de penetración no deben mostrar hallazgos críticos (ERS §3.3.1). En rendimiento, el CRUD simple debe responder bajo 300 ms en el percentil 95 con carga normal, la página principal debe cargar en menos de 2 segundos y el sistema debe sostener 200 usuarios concurrentes; estas mediciones valen solo con el retraso artificial de 5 segundos desactivado, y la medición con el retraso se informa aparte. En usabilidad, la prueba con cinco usuarios representativos, incluidos adultos mayores, no debe mostrar bloqueos mayores (ERS §3.1.1). En compatibilidad, los flujos principales deben funcionar en las dos últimas versiones de los cuatro navegadores y en vistas de móvil y tablet.

**Reglas de negocio.** Con token de paciente, toda operación de escritura debe responder 403 y el paciente solo puede ver sus propios exámenes (RB-1). La administración de usuarios y roles debe estar disponible para el administrador y rechazada para cualquier otro rol (RB-2). RB-3 se acepta si el médico accede a la información clínica tal como lo indica el ERS, y se registra al mismo tiempo la observación de cumplimiento OC-01 (sección 6.3).

**Normativos.** El acceso a la información clínica debe limitarse a quien participa en la atención y quedar registrado con fecha y persona (Ley 20.584 art. 13 y DS 41 art. 9), por lo que una descarga sin registro de auditoría se considera falla. Los datos clínicos no se eliminan físicamente antes de 15 años (Ley 20.584 art. 13 y DS 41 art. 11). Las contraseñas y los secretos no pueden quedar en texto plano ni en el repositorio (Ley 19.628 art. 11).

**Certificación.** El sistema puede recibir el dictamen Certificado solo si no hay incidentes críticos abiertos, todos los casos P0 están aprobados y los 40 códigos tienen un resultado de ejecución. Con incidentes graves abiertos que tengan plan de corrección, el máximo es Certificado con reservas. Con un incidente crítico abierto, el dictamen es No certificado.

## 3.4 Herramientas utilizadas

**Tabla 7. Herramientas de prueba**

| Herramienta | Fundamento de uso en Cuidarte+ | Casos |
|---|---|---|

| Herramienta | Fundamento de uso en Cuidarte+ | Casos |
|---|---|---|
| Selenium | Planificado para repetir los flujos por rol en el frontend. El 27 de octubre de 2026 se ejecutó una suite de 11 pruebas con pytest y Page Objects en Chrome, que cubrió login inválido y válido, logout, listado y edición de pacientes y exámenes, acceso por rol a usuarios y Mis Resultados del paciente. Las 11 pasaron y cada una dejó captura, además de un reporte HTML y JSON | CP-01, 02, 07, 08, 10, 11 y 12 en la capa de interfaz; CP-09 y 22 sin Selenium |
| Postman / Swagger | Prueba la API directamente: códigos HTTP, reutilización de tokens y respuestas por rol | CP-01, 03, 07, 08, 11 a 13 |
| OWASP ZAP | Análisis dinámico autenticado con token de médico y de paciente; en la EV1 solo se hizo el escaneo sin sesión. Se ejecutó el 26 de octubre con la versión 2.17 | CP-04 |
| Burp Suite | Planificado para manipular peticiones manualmente (rol, identificadores y cabeceras). No se usó. El 26 de octubre el mismo criterio se probó con Swagger, cambiando el token con Authorize, y con curl -i | CP-04, CP-17 (reemplazado) |
| Nikto | Planificado para revisar la configuración del servidor web y las cabeceras. No se usó porque no estaba instalado. Las cabeceras se revisaron con curl -I y la configuración de nginx y de Docker Compose | CP-04, CP-14 (reemplazado) |
| SQLMap | Búsqueda de inyección SQL en el login y en los parámetros de las rutas | CP-04 |
| John the Ripper | Mide la resistencia de las contraseñas almacenadas en la base de prueba. Se ejecutó en Docker el 26 de octubre | CP-15 |
| JMeter | Planificado para el tiempo de respuesta CRUD, la descarga de documentos y 200 usuarios concurrentes, reutilizando el plan de carga de la EV1. Se ejecutó en Docker el 26 de octubre solo para CP-05 con el retraso activo. La corrida sin retraso, el tiempo de descarga de CP-13 y CP-19 no se ejecutaron | CP-05 (ejecutado); CP-13 y CP-19 (no ejecutados) |
| SonarQube | Análisis estático del backend y del frontend; sus hallazgos se leen frente a OWASP y a la normativa | CP-16, CP-17 |
| Lighthouse | Accesibilidad básica y tiempo de carga de la página principal. Se ejecutó solo en CP-06; la medición de carga de CP-19 no se ejecutó | CP-06 (ejecutado); CP-19 (no ejecutado) |

Respecto de la EV1 se retiraron Jest y k6. El repositorio no tiene pruebas unitarias ni script de test, y las pruebas de carga se hicieron con JMeter, así que mantenerlos en el plan no era coherente con lo que realmente usamos.

### *Recursos humanos*

**Tabla 8. Roles del equipo**

| Integrante | Rol en la EP3 | Responsabilidades |
|---|---|---|
| Giannina Guerrero | Coordinación de QA e integración | Plan de pruebas, matriz de trazabilidad, análisis ético y normativo, dictamen e integración del informe |
| Nicolás Barra | QA funcional y de API | Casos funcionales y de reglas de negocio, ejecución manual en la interfaz, Postman y SQLMap, suite de 11 pruebas de interfaz con Selenium y registro de la ejecución |

| Integrante | Rol en la EP3 | Responsabilidades |
|---|---|---|
| Skarlett Tropan | QA de calidad y normativa técnica | Criterios y tipos de prueba, SonarQube, verificaciones de TLS, cifrado y respaldo, usabilidad, revisión de CP-17, revisión cruzada y formato del informe |
| Ari Araya | QA de seguridad y rendimiento | Ambiente Docker, OWASP ZAP, Swagger y curl en lugar de Burp Suite y Nikto, John the Ripper, JMeter y clasificación de la criticidad |

Cada parte tiene a otro integrante como revisor, y como la defensa es individual, todos deben poder explicar el trabajo completo y no solo su parte.

### *Recursos técnicos*

**Tabla 9. Recursos técnicos**

| Recurso | Detalle |
|---|---|
| Stack del producto | Backend Node.js 18 (imagen node:18-alpine) con Express 4.19, jsonwebtoken 9 y multer; frontend React 19 con Vite 7, construido con Node 20 y servido por nginx; PostgreSQL 15 (postgres:15-alpine) |
| Orquestación | Docker Compose con tres servicios: frontend :3333, API :4444 (Swagger en /docs) y base de datos :15442 |
| Navegadores | Plan con Chrome, Firefox y Edge en sus dos últimas versiones, Safari si había equipo y vistas móvil y tablet. Ejecutado el 20 de octubre de 2026 en Chrome 155.0.8059.81 y Edge 155.0.4283.45, en escritorio y con 390 px de ancho. Firefox y Safari quedaron bloqueados porque no estaban instalados |
| Automatización de UI | Selenium 4 para Python con pytest, pytest-html, webdriver-manager y Chrome. Suite con Page Objects ejecutada el 27 de octubre de 2026 contra http://localhost:3333, con 11 de 11 pruebas aprobadas |
| Datos de prueba | Cuentas admin, medico y paciente de la base de prueba, con contraseña igual al nombre (ver CP-15), y un paciente de prueba creado en CP-09; pacientes y exámenes ficticios, sin RUT ni datos reales. Las fichas de la sección 4.3 se diseñaron con cuentas admin.qa, medico.qa y paciente.qa y con 375 px, y la ejecución usó las cuentas y el ancho de esta tabla |
| Código fuente | Repositorio Barrolas/cuidarte-mas, rama main (commit 7503d1b al iniciar el ciclo y a6028a5 para las evidencias hasta el 27 de octubre de 2026) |

### *Entorno de prueba*

Todas las pruebas se ejecutaron en el ambiente local Docker de cada integrante. No existe un ambiente de QA o *staging* separado, por lo que las verificaciones que dependen de producción, como TLS con certificado válido o la disponibilidad mensual, se hicieron sobre la configuración del despliegue (la configuración de nginx y de Docker Compose) y se informan con esa limitación. Esa limitación no cambia el resultado de CP-14, que quedó Fallido. El 20 de octubre el frontend y la API respondieron solo por HTTP, sin certificado ni HSTS, y PostgreSQL tiene ssl en off. Las herramientas de seguridad se usaron solo contra esta instalación local.

# 4. Diseño de casos de prueba

## 4.1 Matriz de trazabilidad

En la EV1 la matriz relacionaba 11 filas con seis casos y dejaba 21 de los 40 códigos del ERS B sin caso. Para la EP3 la reconstruimos completa: cada requisito funcional, no funcional y regla de negocio tiene un caso asignado con un identificador que no cambia durante la ejecución. CP-01 a CP-06 conservan su número de la EV1 para no romper la relación con las evidencias ya entregadas, y CP-07 a CP-23 son nuevos. La columna Riesgo usa la priorización de la sección 3.1.

**Tabla 10. Matriz de trazabilidad ERS B, 40 de 40 códigos**

| Código | Requisito (ERS B) | Caso | Tipo de prueba | Riesgo | Ejecuta |
|---|---|---|---|---|---|
| **REQUISITOS FUNCIONALES (17)** | | | | | |
| RF-1.1 | Autenticarse con nombre_usuario y contraseña | CP-01 | Funcional y seguridad | P0 | Nicolás |
| RF-1.2 | Cierre de sesión y revocación de tokens | CP-07 | Seguridad de sesión | P0 | Nicolás |
| RF-2.1 | Registro rápido con usuario, contraseña y correo; rol paciente por defecto | CP-09 | Funcional; valores límite | P2 | Nicolás |
| RF-2.2 | Médico o administrador registra a un paciente | CP-10 | Funcional | P2 | Nicolás |
| RF-2.3 | Médico o administrador edita el registro de un paciente | CP-10 | Funcional | P2 | Nicolás |
| RF-2.4 | Médico o administrador visualiza el registro de un paciente | CP-10 | Funcional; control de acceso | P0 | Nicolás |
| RF-2.5 | Administrador visualiza los usuarios registrados | CP-08 | Funcional; RBAC | P0 | Nicolás |
| RF-2.6 | Administrador edita un usuario y le asigna roles | CP-08 | Funcional; RBAC | P0 | Nicolás |
| RF-2.7 | Administrador elimina un usuario | CP-08 | Funcional; auditoría | P0 | Nicolás |
| RF-3.1 | Médico registra un examen a un paciente | CP-02 | Funcional | P2 | Nicolás |
| RF-3.2 | Médico edita el examen y sus documentos | CP-11 | Funcional | P2 | Nicolás |
| RF-3.3 | Médico elimina el examen o sus documentos (baja lógica con confirmación) | CP-11 | Funcional; cumplimiento | P1 | Nicolás |
| RF-4.1 | Paciente visualiza sus exámenes | CP-12 | Funcional; control de acceso | P0 | Nicolás |
| RF-4.2 | Paciente descarga los documentos de sus exámenes (máximo 10 s) | CP-13 | Funcional; rendimiento | P0 | Nicolás |
| RF-4.3 | Médico adjunta un documento por examen en PDF, DOC, PPT, JPG o PNG | CP-13 | Funcional; partición de equivalencia | P2 | Nicolás |
| RF-4.4 | Documentos en storage interno y referenciados en la BD | CP-13 | Integración | P1 | Nicolás |
| RF-5.1 | Auditar creación, edición, eliminación y subida o descarga de documentos | CP-03 | Funcional; cumplimiento | P1 | Nicolás |
| **REQUISITOS NO FUNCIONALES (20)** | | | | | |
| NFR-SEG-1 | TLS obligatorio en todas las comunicaciones | CP-14 | Seguridad; verificación de configuración | P0 | Skarlett |

| Código | Requisito (ERS B) | Caso | Tipo de prueba | Riesgo | Ejecuta |
|---|---|---|---|---|---|
| NFR-SEG-2 | Contraseñas con hashing seguro (bcrypt) | CP-15 y CP-01 | Seguridad | P0 | Ari |
| NFR-SEG-3 | Cifrado de datos sensibles en reposo | CP-16 | Seguridad; verificación de configuración | P0 | Skarlett |
| NFR-SEG-4 | Control de acceso por rol en el backend | CP-04 y CP-08 | Seguridad | P0 | Ari |
| NFR-SEG-5 | Protección contra CSRF, XSS e inyección SQL; validación y saneamiento | CP-04 | Seguridad | P0 | Ari |
| NFR-SEG-6 | Gestión de log segura | CP-17 | Seguridad; cumplimiento | P1 | Skarlett |
| NFR-SEG-7 | Políticas de respaldo y recuperación definidas | CP-18 | Operación; verificación de configuración | P1 | Skarlett |
| NFR-SEG-8 | Cumplimiento de la normativa de protección de datos personales | CP-23 (con CP-03 y CP-04) | Cumplimiento normativo | P0 | Giannina |
| NFR-SEG-9 | Manejo de sesión con token de acceso (JWT) | CP-01 y CP-07 | Seguridad de sesión | P0 | Nicolás y Ari |
| NFR-PERF-1 | CRUD simple bajo 300 ms con carga normal | CP-05 | Rendimiento | P3 | Ari |
| NFR-PERF-2 | Página principal bajo 2 s en conexión móvil promedio | CP-19 | Rendimiento | P3 | Ari |
| NFR-PERF-3 | 200 usuarios concurrentes por defecto | CP-19 | Carga | P3 | Ari |
| NFR-USAB-1 | Tipografía legible, contraste y controles grandes para personas mayores | CP-06 | Usabilidad; accesibilidad | P4 | Skarlett |
| NFR-USAB-2 | Flujos claros de registro y de visualización de exámenes o documentos | CP-06 | Usabilidad | P4 | Skarlett |
| NFR-USAB-3 | Ayuda contextual y mensajes de error amigables | CP-20 | Usabilidad | P4 | Skarlett |
| NFR-USAB-4 | Primero se accede al paciente y luego a sus exámenes | CP-06 | Usabilidad; flujo | P4 | Skarlett |
| NFR-DIS-1 | Disponibilidad objetivo de 99,5 % mensual | CP-21 | Disponibilidad; verificación documental | P3 | Ari |
| NFR-DIS-2 | Mantenimiento con ventana y migración segura de datos | CP-21 | Mantenibilidad; verificación documental | P3 | Ari |
| NFR-COMPAT-1 | Últimas dos versiones de Chrome, Firefox, Safari y Edge | CP-22 | Compatibilidad | P4 | Skarlett |
| NFR-COMPAT-2 | Responsivo en móviles y tablets | CP-06 | Compatibilidad | P4 | Skarlett |
| **REGLAS DE NEGOCIO (3)** | | | | | |
| RB-1 | Un paciente solo tiene permisos de lectura | CP-04 | Seguridad; RBAC | P0 | Ari |
| RB-2 | El administrador tiene acceso completo de escritura, lectura, actualización y eliminación | CP-08 | Funcional; RBAC | P0 | Nicolás |
| RB-3 | Un médico puede ver la información clínica de cualquier paciente registrado | CP-10 y CP-02 | Funcional; cumplimiento | P0 | Nicolás |

**Tabla 11. Cobertura de diseño, EV1 frente a EP3**

| Bloque | Códigos en el ERS | Con caso en la EV1 | Con caso en la EP3 |
|---|---|---|---|
| Requisitos funcionales | 17 | 4 | 17 |
| Requisitos no funcionales | 20 | 8 | 20 |
| Reglas de negocio | 3 | 2 | 3 |
| **Total** | **40** | **14** | **40 (100 %)** |

La cobertura de diseño queda en 40 de 40. Esto significa que ningún código del ERS queda sin un caso que lo verifique, pero todavía no dice si el sistema cumple. En la EV1 la columna Cobertura marcaba como cubierto todo requisito con un caso diseñado; ahora separamos las dos cosas, y la cobertura de ejecución se mide con los resultados de la sección 5.

Dos situaciones del ERS se dejan explícitas. RF-4.3 acepta PDF, DOC, PPT, JPG y PNG, pero el filtro de carga del backend solo admite PDF, JPG y PNG. Además, RF-4.4 pide guardar los documentos en almacenamiento interno con referencia en la base de datos, mientras que el backend guarda el archivo completo en una columna bytea. CP-13 revisa ambos puntos (INC-15 e INC-16).

## 4.2 Catálogo de casos

**Tabla 12. Casos de prueba de la EP3**

| Caso | Nombre | Códigos ERS | Herramienta | Ejecuta |
|---|---|---|---|---|
| CP-01 | Autenticación válida y rechazo de credenciales inválidas | RF-1.1, NFR-SEG-2, NFR-SEG-9 | Interfaz manual, Postman/Swagger y Selenium (AUTH-01 y AUTH-02, 27 oct 2026) | Nicolás |
| CP-02 | Registro de examen médico por un profesional autorizado | RF-3.1, RB-3 | Interfaz manual y Postman. Selenium cubrió el listado de exámenes (EXA-01) | Nicolás |
| CP-03 | Registro de auditoría ante acciones críticas, incluida la subida y la descarga | RF-5.1, NFR-SEG-8 | Postman, consulta a la tabla auditoria | Nicolás |
| CP-04 | Control de acceso por rol y resistencia a inyección | NFR-SEG-4, NFR-SEG-5, NFR-SEG-8, RB-1 | OWASP ZAP autenticado, SQLMap, Swagger y curl (Burp Suite y Nikto planificados, reemplazados por Swagger y curl) | Ari y Nicolás |
| CP-05 | Tiempo de respuesta de operaciones CRUD con y sin el retraso de 5 s | NFR-PERF-1 | JMeter | Ari |
| CP-06 | Usabilidad para adulto mayor y compatibilidad responsive | NFR-USAB-1, 2 y 4, NFR-COMPAT-2 | Lista de verificación manual, Lighthouse | Skarlett |
| CP-07 | Cierre de sesión y revocación del token | RF-1.2, NFR-SEG-9 | Postman/Swagger y Selenium en la interfaz (AUTH-03) | Nicolás |
| CP-08 | Administración de usuarios por el administrador: listar, editar rol y eliminar | RF-2.5, 2.6, 2.7, NFR-SEG-4, RB-2 | Interfaz manual, Postman y Selenium (RBAC-01 y RBAC-02) | Nicolás |
| CP-09 | Registro rápido con rol paciente y política de contraseña | RF-2.1 | Interfaz manual, sin Selenium | Nicolás |

| Caso | Nombre | Códigos ERS | Herramienta | Ejecuta |
|---|---|---|---|---|
| CP-10 | Gestión de pacientes por médico y administrador | RF-2.2, 2.3, 2.4, RB-3 | Interfaz manual, Postman y Selenium (PAC-01 y PAC-02) | Nicolás |
| CP-11 | Edición y baja lógica de exámenes y documentos con confirmación | RF-3.2, RF-3.3 | Interfaz manual, Postman y Selenium (EXA-01 y EXA-02) | Nicolás |
| CP-12 | El paciente ve solo sus propios exámenes | RF-4.1 | Interfaz manual, Postman y Selenium (RES-01 y RBAC-03) | Nicolás |
| CP-13 | Carga y descarga de documentos: formatos, almacenamiento y tiempo | RF-4.2, 4.3, 4.4 | Postman e interfaz manual (tiempos con JMeter sin ejecutar) | Nicolás y Ari |
| CP-14 | Verificación de TLS en frontend y API | NFR-SEG-1 | Revisión de nginx.conf y docker-compose, navegador y curl -I (Nikto planificado, reemplazado por curl) | Skarlett |
| CP-15 | Almacenamiento de contraseñas y resistencia a cracking | NFR-SEG-2 | Consulta a la BD de prueba, John the Ripper | Ari |
| CP-16 | Cifrado en reposo de datos clínicos y documentos | NFR-SEG-3 | Revisión del esquema y de la carpeta uploads, SonarQube | Skarlett |
| CP-17 | Gestión de log y manejo de errores sin fuga de información | NFR-SEG-6 | SonarQube, revisión manual del código, Swagger y curl (Burp Suite planificado, reemplazado por Swagger y curl) | Skarlett y Ari |
| CP-18 | Respaldo y restauración de la base de datos | NFR-SEG-7 | pg_dump y restauración en Docker | Skarlett |
| CP-19 | Carga de la página principal y 200 usuarios concurrentes | NFR-PERF-2, NFR-PERF-3 | Lighthouse, JMeter (no ejecutado al 27 oct 2026) | Ari |
| CP-20 | Ayuda contextual y mensajes de error comprensibles | NFR-USAB-3 | Lista de verificación manual | Skarlett |
| CP-21 | Disponibilidad y procedimiento de mantenimiento | NFR-DIS-1, NFR-DIS-2 | Revisión documental y de docker-compose | Ari |
| CP-22 | Compatibilidad con navegadores | NFR-COMPAT-1 | Revisión manual en Chrome y Edge (Firefox y Safari bloqueados; sin Selenium) | Skarlett |
| CP-23 | Verificación de cumplimiento normativo | NFR-SEG-8 | Checklist de la Tabla 6.1 del análisis normativo | Giannina |

### 4.3 Casos detallados

Se presentan ocho casos con ficha completa, que cubren los distintos tipos de requisito del ERS: funcionales (CP-02, CP-08), de seguridad (CP-01, CP-04, CP-07), de auditoría y cumplimiento (CP-03), de rendimiento (CP-05) y de usabilidad y compatibilidad (CP-06). Las fichas de CP-01 a CP-06 vienen de la EV1 con los ajustes indicados en el Anexo A. Las fichas muestran el diseño. Las herramientas, cuentas y anchos que se usaron en la ejecución están en las tablas 7, 9 y 24.

**Tabla 13. Ficha del caso CP-01**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-01** | Autenticación válida y rechazo de credenciales inválidas | RF-1.1: autenticarse con nombre_usuario y contraseña. NFR-SEG-2: hash seguro de contraseñas. NFR-SEG-9: sesión con token JWT. |
| **DESCRIPCIÓN** | | |
| Verificar que un usuario válido obtiene una sesión JWT, que las credenciales inválidas se rechazan sin revelar si la cuenta existe y que la contraseña no se guarda ni se compara en texto plano. | | |
| **PRECONDICIONES** | | |
| Ambiente Docker local arriba (API en http://localhost:4444). Usuario medico.qa creado con rol médico y contraseña conforme a la política del ERS. | | |
| **PASOS** | | |
| 1. Enviar POST /autenticacion/login con credenciales válidas.<br>2. Verificar que la respuesta trae un token JWT y revisar su expiración.<br>3. Repetir con contraseña incorrecta y con un usuario inexistente.<br>4. Comparar código y mensaje de ambos rechazos.<br>5. Revisar en la tabla de usuarios cómo quedó guardada la contraseña. | | |
| **RESULTADO ESPERADO** | | |
| El login válido responde 200 con un JWT de vigencia acotada. Los dos rechazos responden 401 con el mismo mensaje genérico y sin token. La contraseña se guarda como hash bcrypt. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| Se genera el token solo con credenciales válidas, el rechazo no revela si el usuario existe y no hay contraseñas en texto plano en la base ni en los registros. | | |
| **DATOS DE PRUEBA** | | |
| Válido: medico.qa / PruebaSegura#2026. Inválido: medico.qa / ClaveIncorrecta#1. Inexistente: noexiste.qa / ClaveIncorrecta#1. | | |
| **TIPO DE PRUEBA** | | |
| Funcional y de seguridad | | |

**Tabla 14. Ficha del caso CP-02**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-02** | Registro de examen médico por un profesional autorizado | RF-3.1: el médico registra un examen a un paciente. RB-3: el médico puede ver la información clínica de los pacientes. |

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **DESCRIPCIÓN** | | |
| Validar que un médico autenticado puede crear un examen asociado a un paciente existente y que el servidor valida los campos obligatorios. | | |
| **PRECONDICIONES** | | |
| Sesión activa de médico. Paciente de prueba registrado. | | |
| **PASOS** | | |
| 1. Iniciar sesión como médico.<br>2. Seleccionar el paciente de prueba.<br>3. Registrar un examen con datos válidos y adjuntar un PDF dentro del límite.<br>4. Confirmar que aparece en el listado y en el detalle (GET /examenes/paciente/:paciente_id).<br>5. Intentar guardar un examen sin campos obligatorios, desde la interfaz y con POST /examenes. | | |
| **RESULTADO ESPERADO** | | |
| El examen se crea con respuesta 201 y queda asociado al paciente. El intento sin campos obligatorios se rechaza con un mensaje comprensible, también por API. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| El CRUD de exámenes opera según el ERS, la validación funciona en el servidor y el médico accede a la información clínica según RB-3. | | |
| **DATOS DE PRUEBA** | | |
| Paciente de prueba; tipo de examen hemograma completo; fecha de emisión del día; observación "control rutinario"; PDF de 200 KB. | | |
| **TIPO DE PRUEBA** | | |
| Funcional | | |

**Tabla 15. Ficha del caso CP-03**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-03** | Registro de auditoría ante acciones críticas | RF-5.1: auditar creación, edición y eliminación de registros y subida o descarga de documentos. NFR-SEG-6: gestión de log segura. |

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **DESCRIPCIÓN** | | |
| Comprobar que cada acción crítica, incluidas la subida y la descarga de documentos, genera un registro de auditoría con actor, acción, fecha y recurso, y que nadie puede escribir registros falsos. | | |
| **PRECONDICIONES** | | |
| Examen con documento creado en CP-02. Usuarios médico y paciente disponibles. | | |
| **PASOS** | | |
| 1. Como médico, editar y luego eliminar un examen de prueba.<br>2. Subir un documento a otro examen.<br>3. Como paciente, descargar ese documento (GET /documentos/:id).<br>4. Consultar GET /auditoria y verificar un registro por cada acción.<br>5. Con token de paciente, intentar POST /auditoria con un registro inventado. | | |
| **RESULTADO ESPERADO** | | |
| Existe un registro por cada acción, incluida la descarga, sin contraseñas ni tokens. POST /auditoria con token de paciente se rechaza. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| Se audita cada acción crítica del ERS. La falta de registro de la descarga o la posibilidad de escribir registros desde el cliente hacen fallar el caso. | | |
| **DATOS DE PRUEBA** | | |
| Examen y documento de CP-02; usuarios medico.qa y paciente.qa. | | |
| **TIPO DE PRUEBA** | | |
| Funcional y de cumplimiento (auditoría) | | |

**Tabla 16. Ficha del caso CP-04**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-04** | Control de acceso por rol y resistencia a inyección | NFR-SEG-4: control de acceso por rol en backend. NFR-SEG-5: protección contra CSRF, XSS e inyección SQL. RB-1: el paciente solo lee. |

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **DESCRIPCIÓN** | | |
| Verificar que un paciente no puede ejecutar operaciones de administración ni ver datos ajenos, y que las entradas maliciosas se rechazan o se sanean. | | |
| **PRECONDICIONES** | | |
| Usuarios de los tres roles. OWASP ZAP configurado con token de paciente y de médico. | | |
| **PASOS** | | |
| 1. Autenticarse como paciente y guardar el token.<br>2. Invocar GET /usuarios y DELETE /usuarios/:id.<br>3. Pedir el examen y el documento de otro paciente cambiando el identificador (Burp Suite).<br>4. Ejecutar SQLMap sobre el login y los parámetros de /examenes.<br>5. Enviar <script>alert(1)</script> en observaciones y revisar si se ejecuta.<br>6. Correr ZAP autenticado y Nikto sobre :3333 y :4444. | | |
| **RESULTADO ESPERADO** | | |
| Los accesos indebidos responden 401 o 403. La inyección SQL no autentica ni altera consultas. El script no se ejecuta. ZAP y Nikto no reportan hallazgos altos. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| El control de acceso es efectivo en el backend y no hay hallazgos críticos de inyección ni de acceso a datos de otro paciente. | | |
| **DATOS DE PRUEBA** | | |
| Token de paciente.qa. Login con ' OR 1=1 --. Campo observaciones con <script>alert(1)</script>. Identificador de un examen de otro paciente. | | |
| **TIPO DE PRUEBA** | | |
| No funcional: seguridad | | |

**Tabla 17. Ficha del caso CP-05**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-05** | Tiempo de respuesta de operaciones CRUD bajo carga normal | NFR-PERF-1: operaciones CRUD simples bajo 300 ms con carga normal. |

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **DESCRIPCIÓN** | | |
| Medir el tiempo de respuesta del CRUD de pacientes y exámenes con carga normal y compararlo con el umbral del ERS, con y sin el retraso artificial de 5 s que tiene el backend. | | |
| **PRECONDICIONES** | | |
| Ambiente estable con datos sintéticos y sin otras pruebas en curso. Para la medición formal, delayMiddleware(5000) desactivado en examenes.js, pacientes.js y documentos.js. | | |
| **PASOS** | | |
| 1. Abrir el plan CuidartePlus_CP05.jmx.<br>2. Ejecutar con el retraso activo (línea base de la EV1).<br>3. Desactivar el retraso y reiniciar el backend.<br>4. Ejecutar de nuevo durante cinco minutos.<br>5. Comparar el percentil 95 de cada petición con 300 ms. | | |
| **RESULTADO ESPERADO** | | |
| Sin el retraso, el p95 de las operaciones CRUD simples queda bajo 300 ms durante toda la ventana. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| Se cumple el umbral sin el retraso y se adjunta el reporte HTML de JMeter. La corrida con retraso se informa aparte. | | |
| **DATOS DE PRUEBA** | | |
| Grupo A: 20 usuarios virtuales con GET y POST sobre pacientes y exámenes. Grupo B: 50 usuarios virtuales como prueba de concurrencia. | | |
| **TIPO DE PRUEBA** | | |
| No funcional: rendimiento | | |

**Tabla 18. Ficha del caso CP-06**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-06** | Usabilidad para adulto mayor y compatibilidad responsiva | NFR-USAB-1, 2 y 4 (legibilidad, flujos claros, primero paciente y luego exámenes). NFR-COMPAT-2: responsivo en móvil y tablet. |

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **DESCRIPCIÓN** | | |
| Evaluar que un paciente adulto mayor complete el acceso a sus exámenes en móvil y tablet con texto legible, buen contraste y controles fáciles de tocar. | | |
| **PRECONDICIONES** | | |
| Frontend en http://localhost:3333. Paciente con al menos un examen y un documento. | | |
| **PASOS** | | |
| 1. Abrir la aplicación con viewport de 375 px.<br>2. Iniciar sesión como paciente.<br>3. Ir del perfil al listado de exámenes, al detalle y a la descarga.<br>4. Revisar contraste, tamaño de fuente y de controles con la lista de verificación y Lighthouse.<br>5. Repetir en tablet y en otro navegador. | | |
| **RESULTADO ESPERADO** | | |
| El flujo se completa sin bloqueos, la interfaz se adapta al tamaño de pantalla y el documento se abre o descarga correctamente. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| La sesión con usuarios representativos termina sin bloqueos mayores y se alcanza el puntaje mínimo de la lista de verificación. | | |
| **DATOS DE PRUEBA** | | |
| Viewport 375 px y tablet; usuario paciente.qa; lista de verificación de contraste y tamaño de controles. | | |
| **TIPO DE PRUEBA** | | |
| No funcional: usabilidad y compatibilidad | | |

**Tabla 19. Ficha del caso CP-07**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-07** | Cierre de sesión y revocación del token | RF-1.2: cierre de sesión y revocación de tokens. NFR-SEG-9: sesión con token JWT. |
| **DESCRIPCIÓN** | | |
| Comprobar que, al cerrar sesión, el token emitido deja de ser aceptado por la API, para que una sesión olvidada en un equipo compartido no siga abierta. | | |
| **PRECONDICIONES** | | |
| Ambiente Docker arriba. Usuario médico con al menos un examen visible. | | |
| **PASOS** | | |
| 1. Iniciar sesión con POST /autenticacion/login y guardar el token.<br>2. Consultar GET /examenes con ese token (200).<br>3. Cerrar sesión desde la interfaz y buscar en Swagger un endpoint de logout o revocación.<br>4. Repetir GET /examenes con el mismo token.<br>5. Registrar el código obtenido y cuánto tiempo sigue siendo aceptado el token. | | |
| **RESULTADO ESPERADO** | | |
| Después del cierre de sesión la API responde 401 al token anterior, porque existe un logout que lo invalida en el servidor. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| El logout invalida la sesión (criterio de RF-1). Si el token sigue funcionando, el caso falla aunque la interfaz vuelva a la pantalla de login. | | |
| **DATOS DE PRUEBA** | | |
| Usuario medico.qa; token JWT del paso 1. | | |
| **TIPO DE PRUEBA** | | |
| No funcional: seguridad de sesión, con verificación funcional del cierre | | |

**Tabla 20.** **Ficha del caso CP-08**

| ID | NOMBRE | REQUERIMIENTO |
|---|---|---|
| **CP-08** | Administración de usuarios por el administrador | RF-2.5, RF-2.6 y RF-2.7 (listar, editar con roles y eliminar usuarios). NFR-SEG-4. RB-2. |
| **DESCRIPCIÓN** | | |
| Verificar que el administrador puede gestionar usuarios de punta a punta y que ningún otro rol puede hacerlo, ni por /usuarios ni por /roles. | | |
| **PRECONDICIONES** | | |
| Cuentas de administrador y de médico. Un usuario sintético creado para editar y eliminar. | | |
| **PASOS** | | |
| 1. Como administrador, listar con GET /usuarios.<br>2. Editar el usuario de prueba con PUT /usuarios/:id y asignarle rol médico.<br>3. Eliminarlo desde la interfaz y verificar que pide confirmación.<br>4. Revisar en la base y en la auditoría si la baja fue lógica o física.<br>5. Como médico, repetir PUT /usuarios/:id e intentar POST /roles y DELETE /roles/:id. | | |
| **RESULTADO ESPERADO** | | |
| El administrador lista, edita y elimina con respuesta 200; la eliminación pide confirmación, queda auditada y es lógica. Con token de médico, /usuarios y /roles responden 403. | | |
| **CRITERIO DE ACEPTACIÓN** | | |
| Las tres operaciones funcionan solo para el administrador y el control se aplica en el backend. Cualquier operación de administración aceptada con otro rol hace fallar el caso. | | |
| **DATOS DE PRUEBA** | | |
| Usuario sintético usuario.prueba08 con correo ficticio; tokens de admin.qa y medico.qa. | | |
| **TIPO DE PRUEBA** | | |
| Funcional y de seguridad (control de acceso) | | |

# 5. Ejecución de pruebas

## 5.1 Resumen de ejecución

El diseño de la EP3 contempla 23 casos que cubren los 40 códigos del ERS B. Las tablas siguientes resumen el ciclo 2 con los números de la sección 5.2, y ambas cifras cuadran.

**Tabla 21.** **Resumen general de la ejecución**

| Indicador | Valor |
|---|---|
| Requisitos del ERS cubiertos por diseño | 40 de 40 (100 %) |
| Casos de prueba diseñados | 23 (CP-01 a CP-23) |
| Casos ejecutados | 22 de 23 (96 %). Tres de ellos quedan parciales: CP-04, CP-13 y CP-22 |
| Aprobados | 7 (CP-01, CP-02, CP-08, CP-09, CP-10, CP-11 y CP-12) |
| Fallidos | 12 (CP-03, CP-05, CP-06, CP-07, CP-14, CP-15, CP-16, CP-17, CP-18, CP-20, CP-21 y CP-23) |
| Parciales | 3 (CP-04, CP-13 y CP-22). En CP-22, Firefox y Safari no se probaron porque no estaban instalados |
| No ejecutados | 1 (CP-19, sin ejecutar al 27 de octubre de 2026) |

| Indicador | Valor |
|---|---|
| Resultado por requisito | 40 códigos: 10 aprobados, 10 parciales, 18 fallidos y 2 sin resultado (NFR-PERF-2 y NFR-PERF-3, por CP-19) |
| Incidentes registrados por severidad | Confirmados en la ejecución (9): INC-01, INC-03, INC-04, INC-05, INC-13, INC-14, INC-15, INC-16 e INC-17 (nuevo, CP-21). Confirmados en la revisión del código, sin prueba dinámica (5): INC-02, INC-06, INC-07, INC-08 e INC-09. Sin confirmar (3): INC-10 parcial, INC-11 no ejecutado e INC-12 no confirmado.<br>Severidad: 1 crítico, 9 graves y 7 moderados, 17 incidentes en total (ver 5.3) |

**Tabla 22. Resultados por tipo de prueba**

| Tipo de prueba | Diseñados | Ejecutados | Aprobados | Fallidos | Parciales |
|---|---|---|---|---|---|
| Funcionales | 7 | 7 | 7 | 0 | 0 |
| Integración y auditoría | 2 | 2 | 0 | 1 | 1 |
| Seguridad | 4 | 4 | 0 | 3 | 1 |
| Configuración y cumplimiento | 5 | 5 | 0 | 5 | 0 |
| Rendimiento | 2 | 1 | 0 | 1 | 0 |
| Usabilidad y compatibilidad | 3 | 3 | 0 | 2 | 1 |
| **Total** | **23** | **22** | **7** | **12** | **3** |

Las tablas 21 y 22 cuadran con la Tabla 24. De los 22 casos ejecutados, 7 se aprueban, 12 fallan y 3 quedan parciales (CP-04, CP-13 y CP-22); los parciales no se cuentan como aprobados ni como fallidos. El único caso sin ejecutar es CP-19, que mide la carga de la página principal y los 200 usuarios concurrentes. Los resultados de Nicolás Barra salen de su bitácora del 20 de octubre de 2026, los de Skarlett Tropan de las capturas y verificaciones del 20 de octubre de 2026 listadas en el Anexo B, los de Ari Araya de su bitácora del 26 de octubre de 2026 y el cierre de CP-17 de la revisión del código que hizo Skarlett Tropan el 27 de octubre de 2026. CP-23 es una revisión documental hecha sobre esos resultados.

### *Evidencia previa de la EV1*

En la EV1 hicimos una ejecución exploratoria los días 7 y 8 de septiembre de 2026 en el mismo ambiente Docker. No reemplaza al ciclo 2 de la EP3, pero sirve como línea base y adelanta resultados que la ejecución debe confirmar.

**Tabla 23. Resultados exploratorios de la EV1 (línea base)**

| Caso | Prueba realizada en la EV1 | Resultado observado | Fuente |
|---|---|---|---|
| CP-01 | Login con el usuario semilla medico/medico | 200 con JWT; la contraseña se compara en texto plano (HALL-02) | Informe de hallazgos EV1 |

| Caso | Prueba realizada en la EV1 | Resultado observado | Fuente |
|---|---|---|---|
| CP-04 | Paciente invoca GET /usuarios | 403: el control de rol funciona en esa ruta | Informe de hallazgos EV1 |
| CP-04 | Login con ' OR 1=1 -- | 401 sin token (consulta parametrizada) | Informe de hallazgos EV1 |
| CP-04 | OWASP ZAP baseline sin sesión (frontend y API) | 0 FAIL; advertencias por cabeceras faltantes (CSP, anti-clickjacking, X-Content-Type-Options), X-Powered-By y CORS amplio | Informe OWASP ZAP EV1 y anexos |
| CP-05 | JMeter, 220 muestras, retraso activo | Login p95 de unos 14 ms (cumple); GET /pacientes y /examenes p95 de unos 5.008 a 5.011 ms (no cumple); 0 % de error | Informe JMeter CP-05 |
| CP-02, CP-06 | Botón Ver Documento en el formulario de examen | Abre el selector de archivos en lugar del documento (HALL-01); la API sí responde 200 con el PDF | Informe de hallazgos EV1 |

## 5.2 Detalle de ejecución de casos

Cada caso se registra con su resultado, la evidencia (captura o archivo de la herramienta), el incidente asociado cuando falla y la fecha y persona que lo ejecuta. La columna Incidente esperado indica lo que la revisión del código hace prever; si la ejecución no lo confirma, se deja constancia.

**Tabla 24. Detalle de ejecución por caso**

| Caso | Descripción | Resultado | Evidencia | Incidente esperado | Fecha / ejecuta |
|---|---|---|---|---|---|
| **PRUEBAS: FUNCIONALES** | | | | | |
| CP-01 | Autenticación válida y rechazo de credenciales inválidas | Aprobado | 20 oct 2026. UI y Postman. El médico inicia sesión en la UI y la API responde 200 con JWT. Con credenciales inválidas la UI muestra el error y la API responde 401. Evidencias/CP-01Evidencias/CP-01selenium-login-medico.png, capturas 01 a 05. El 27 oct 2026 la suite de Selenium repitió el login inválido y el del médico, ambos aprobados (AUTH-01 y AUTH-02), y antes la prueba de humo llegó a /home (selenium-smoke-output.txtselenium-login-medico.png y selenium-smoke-output.txt). | INC-01 e INC-02 no se observan en este caso. INC-01 queda para CP-15. | 20 oct 2026 Nicolás Barra |
| CP-02 | Registro de examen médico por un profesional autorizado | Aprobado | 20 oct 2026. UI y Postman. El médico registra un examen de glicemia a la paciente Javiera y la API lo devuelve con id 3. El aviso de éxito aparece antes de que se actualice la lista (REC-08). Evidencias/CP-02, capturas 01 y 02. | INC-04 no se mide aquí, queda para CP-05. | 20 oct 2026 Nicolás Barra |
| CP-08 | Administración de usuarios por el administrador: listar, editar rol y eliminar | Aprobado | 20 oct 2026. UI y Postman. El administrador lista los usuarios y el borrado pide confirmación. Un médico recibe 403 en GET /usuarios. La columna Rol aparece como N/A. Evidencias/CP-08Evidencias/CP-08, capturas 01 a 03. El 27 oct 2026 la suite de Selenium confirmó que el médico no ve el panel de usuarios y el administrador sí (RBAC-01 y RBAC-02). | INC-07 e INC-09 no se probaron: no hubo edición de rol, llamada a /roles ni revisión del borrado en la BD. | 20 oct 2026 Nicolás Barra |

| Caso | Descripción | Resultado | Evidencia | Incidente esperado | Fecha / ejecuta |
|---|---|---|---|---|---|
| CP-09 | Registro rápido con rol paciente y política de contraseña | Aprobado | 20 oct 2026. UI. El administrador crea el usuario paciente-prueba con rol Paciente y este inicia sesión. Al cambiar la contraseña, una clave corta se rechaza con un mínimo de 8 caracteres. No se usó el /registro público. Evidencias/CP-09Evidencias/CP-09, capturas 01 a 05. | INC-10: el mínimo visto es 8, bajo los 12 que pide el ERS. Falta probar /registro. | 20 oct 2026 Nicolás Barra |
| CP-10 | Gestión de pacientes por médico y administrador | Aprobado | 20 oct 2026. UI y Postman. Funciona el listado de pacientes y la edición de la paciente Elva se ve en la UI y en la API, antes y después. El teléfono de emergencia acepta texto sin validar (REC-09 y REC-10). Evidencias/CP-10, capturas 00 a 03. El 27 oct 2026 la suite de Selenium repitió el listado y la apertura de la edición de pacientes (PAC-01 y PAC-02). | OC-01 se analiza en la sección 6. | 20 oct 2026 Nicolás Barra |
| CP-11 | Edición y baja lógica de exámenes y documentos con confirmación | Aprobado | 20 oct 2026. UI y Postman. La edición del examen se refleja en la UI y en la API. En la lista del médico solo aparece el lápiz, sin opción de eliminar el examen, y los documentos solo los borra el administrador (visto en CP-03). Evidencias/CP-11, capturas 01, 01a y 02. El 27 oct 2026 la suite de Selenium repitió la edición y el guardado de observaciones de un examen (EXA-01 y EXA-02). | INC-09 no se probó porque no hubo eliminación. | 20 oct 2026 Nicolás Barra |
| CP-12 | El paciente ve solo sus propios exámenes | Aprobado | 20 oct 2026. UI y Postman. El paciente ve solo sus exámenes y GET /examenes con su token devuelve solo los de paciente_id 1. Evidencias/CP-12, capturas 01 a 03. El 27 oct 2026 la suite de Selenium confirmó que el menú del paciente muestra Mis Resultados sin Usuarios ni Auditoría (RES-01 y RBAC-03). | Ninguno. | 20 oct 2026 Nicolás Barra |
| **PRUEBAS: INTEGRACIÓN Y AUDITORÍA** | | | | | |
| CP-03 | Registro de auditoría ante acciones críticas, incluida la subida y la descarga | Fallido | 20 oct 2026. UI y Postman. La subida de un documento queda auditada como DOCUMENTOS_CREAR, pero la descarga no deja registro. Un médico crea un registro inventado con POST /auditoria y recibe 201. Evidencias/CP-03, capturas 01 a 05. | INC-13 e INC-14 confirmados. | 20 oct 2026 Nicolás Barra |
| CP-13 | Carga y descarga de documentos: formatos, almacenamiento y tiempo | Parcial | 20 oct 2026. UI. PDF, JPG y PNG se cargan bien. DOCX y PPTX se rechazan sin ningún mensaje (REC-07). El tiempo de descarga de 10 s no se midió, y el 26 de octubre tampoco, porque la base no tenía documentos. Evidencias/CP-13Evidencias/CP-13, capturas 01 a 05a. | INC-15 confirmado. INC-16 parcial aquí y confirmado en CP-16. INC-12 sin verificar. | 20 oct 2026 Nicolás Barra (flujo). El tiempo no se midió |
| **PRUEBAS: SEGURIDAD** | | | | | |
| CP-04 | Control de acceso por rol y resistencia a inyección | Parcial | 20 oct 2026. SQLMap y Postman. SQLMap no encontró parámetros inyectables y los payloads manuales tipo OR 1=1 en el login devuelven 401. 26 oct 2026. ZAP 2.17.0 con token de médico y de paciente terminó con 0 alertas altas, 2 medias y 4 bajas (reporte no exportado). | INC-05 confirmado en CORS y cabeceras. El límite de intentos de login no se | 20 y 26 oct 2026 Nicolás Barra (SQLMap). Ari |

| Caso | Descripción | Resultado | Evidencia | Incidente esperado | Fecha / ejecuta |
|---|---|---|---|---|---|
| | | | Con curl, la API responde CORS * y X-Powered-By: Express, sin CSP, X-Frame-Options, X-Content-Type-Options ni HSTS. Con token de paciente, las escrituras y los datos de otro paciente responden 403, y sin token 401. Burp y Nikto no se usaron. | probó. INC-08 no se probó. | Araya (ZAP, cabeceras y control de acceso) |
| CP-07 | Cierre de sesión y revocación del token | Fallido | 20 oct 2026. UI y Postman. Al cerrar sesión la UI vuelve al login, pero el mismo JWT sigue respondiendo 200 en GET /examenes. Evidencias/CP-07, capturas 01 a 03. El 27 oct 2026 la suite de Selenium confirmó en la interfaz el regreso al login (AUTH-03). El resultado se mantiene, porque el token sigue válido en la API. | INC-03 confirmado. | 20 oct 2026 Nicolás Barra |
| CP-15 | Almacenamiento de contraseñas y resistencia a cracking | Fallido | 26 oct 2026. psql y John the Ripper. La columna contrasena es text y guarda admin, medico y paciente sin hash, iguales al nombre de usuario. El login medico/medico responde 200. John the Ripper no carga ningún hash. | INC-01 confirmado. | 26 oct 2026 Ari Araya |
| CP-17 | Gestión de log y manejo de errores sin fuga de información | Fallido | 20 oct 2026. SonarQube no marcó *Security Hotspots*Security Hotspots ni la fuga de mensajes (sección 5.4). 26 oct 2026. Swagger y curl en lugar de Burp Suite. Los rechazos 401 y 403 devuelven mensajes genéricos y POST /documentos respondió 500 sin que se guardara el cuerpo. 27 oct 2026. Revisión del código de main con 34 bloques catch en ocho rutas que responden glosa con err.message y escriben console.error(err). El log de acceso es morgan en formato dev, sin redacción. | INC-06 confirmado en el código; falta la captura del cuerpo de un 500. INC-14 confirmado en CP-03. INC-11 no ejecutado al 27 oct 2026, sin npm audit. | 20, 26 y 27 oct 2026 Skarlett Tropan y Ari Araya |
| **PRUEBAS: CONFIGURACIÓN Y CUMPLIMIENTO** | | | | | |
| CP-14 | Verificación de TLS en frontend y API | Fallido | 20 oct 2026. HTTP 200 en los puertos 3333 y 4444. HTTPS no conecta. nginx solo escucha el puerto 80, sin HSTS. PostgreSQL con ssl=off. | Ninguno previo. Incumple NFR-SEG-1. | 20 oct 2026 Skarlett Tropan |
| CP-16 | Cifrado en reposo de datos clínicos y documentos | Fallido | Sin pgcrypto. Datos clínicos y contraseña en text. Documento en bytea. Un archivo de prueba en /files/documentos respondió 200 sin sesión y se eliminó. | INC-16 | 20 oct 2026 Skarlett Tropan |
| CP-18 | Respaldo y restauración de la base de datos | Fallido | pg_dump restauró los mismos conteos (3 usuarios, 20 pacientes, 6 auditorías) y la base de prueba se eliminó. No hay programación, retención ni copia externa. | Ninguno previo. Incumple NFR-SEG-7. | 20 oct 2026 Skarlett Tropan |
| CP-21 | Disponibilidad y procedimiento de mantenimiento | Fallido | 26 oct 2026. Revisión documental de docker-compose y nginx. Los tres contenedores quedan *healthy*, pero hay una sola réplica, reinicio unless-stopped, healthcheck sin start_period y solo HTTP en el puerto 80. No hay respaldo automático, ventana de mantenimiento ni medición del 99,5 %. | INC-17, nuevo. NFR-DIS-1 y NFR-DIS-2 no se pueden demostrar. | 26 oct 2026 Ari Araya |
| CP-23 | Verificación de cumplimiento normativo | Fallido | 26 oct 2026. Revisión documental con las exigencias de la Tabla 29, cruzadas con los resultados de esta tabla. No se | INC-03, INC-13 e INC-14. | 26 oct 2026 Giannin |

| Caso | Descripción | Resultado | Evidencia | Incidente esperado | Fecha / ejecuta |
|---|---|---|---|---|---|
| | | | cumplen el DS 41 art. 9 (CP-03), el DS 41 art. 8 (CP-14 y CP-18) ni la Ley 20.584 art. 13 (CP-07). CP-16 deja una brecha frente a la Ley 21.719. Detalle en la sección 6.4. | Además, CP-14 y CP-18 sin ID. | a Guerrero |
| **PRUEBAS: RENDIMIENTO** | | | | | |
| CP-05 | Tiempo de respuesta de operaciones CRUD con y sin el retraso de 5 s | Fallido | 26 oct 2026. JMeter con el plan de la EV1 y el retraso activo. 220 muestras en 59 s con 70 usuarios, promedio 2965 ms, máximo 5016 ms y 0 % de error. Las consultas de pacientes y exámenes promedian entre 5008 y 5011 ms. La corrida sin retraso no se hizo. Línea base EV1: p95 cercano a 5 s con retraso. | INC-04 confirmado. | 26 oct 2026 Ari Araya |
| CP-19 | Carga de la página principal y 200 usuarios concurrentes | No ejecutado | No se corrió Lighthouse sobre la página principal ni la prueba con 200 usuarios concurrentes. | INC-04, sin medir en este caso. | Sin fecha Ari Araya |
| **PRUEBAS: USABILIDAD Y COMPATIBILIDAD** | | | | | |
| CP-06 | Usabilidad para adulto mayor y compatibilidad responsive | Fallido | Lighthouse accesibilidad 0,96. Contraste bajo en Entrar, Regístrate y Guía inicial. Etiquetas de 12,25 px. En 390 px el login ocupa media pantalla. INC-12 no se reejecutó: 0 documentos. | INC-12, no confirmado | 20 oct 2026 Skarlett Tropan |
| CP-20 | Ayuda contextual y mensajes de error comprensibles | Fallido | La validación y «Credenciales inválidas» son claras. La ayuda es un diálogo y la página /ayuda, no está junto a los campos. INC-06 no se reprodujo en el login. | INC-06 no reproducido en este caso; confirmado en el código en CP-17 | 20 oct 2026 Skarlett Tropan |
| CP-22 | Compatibilidad con navegadores | Parcial. Aprobado en Chrome y Edge; Firefox y Safari sin probar (no instalados). | Chrome 155.0.8059.81 y Edge 155.0.4283.45 muestran el mismo login. Firefox y Safari no están instalados. No se probó la versión anterior. | Ninguno | 20 oct 2026 Skarlett Tropan |

Los casos de configuración, usabilidad y compatibilidad (CP-06, CP-14, CP-16, CP-18, CP-20 y CP-22) se ejecutaron el 20 de octubre de 2026. El detalle está en la Tabla 24. Los casos funcionales y de integración (CP-01 a CP-03 y CP-07 a CP-13) y la parte de SQLMap de CP-04 los ejecutó Nicolás Barra el mismo día, según su bitácora. Los casos de seguridad, rendimiento y disponibilidad (la parte dinámica de CP-04, CP-05, CP-15, CP-17 y CP-21) los ejecutó Ari Araya el 26 de octubre de 2026, y Skarlett Tropan cerró CP-17 el 27 de octubre con la revisión del código. CP-19 no alcanzó a correrse y queda como no ejecutado al 27 de octubre de 2026. CP-23 se resolvió como revisión documental sobre estos resultados y su detalle está en la sección 6.4.

CP-14 falla frente a NFR-SEG-1. En el contenedor del frontend, nginx escucha solo el puerto 80 y no redirige a HTTPS. docker-compose publica el frontend en 3333:80 y la API en 4444:4000, sin certificados. Ese día ambas URLs respondieron HTTP/1.1 200 y la conexión HTTPS falló. No aparece el encabezado Strict-Transport-*Security*. PostgreSQL tiene ssl en off. Nikto no estaba instalado en el equipo, así que la verificación se hizo con la configuración y con curl.

CP-16 falla frente a NFR-SEG-3 y confirma INC-16 en la parte del archivo. La base no tiene la extensión pgcrypto. Las alergias, las enfermedades crónicas, las observaciones, el diagnóstico y la contraseña están en columnas text, y el documento del examen está en bytea, sin cifrado. Se dejó un archivo sintético en la carpeta de documentos y GET /files/documentos lo devolvió con 200 sin token. El archivo se eliminó al terminar la prueba. El hallazgo de SonarQube sobre la contraseña de PostgreSQL en el código queda en la sección 5.4.

CP-18 falla frente a NFR-SEG-7 porque el despliegue no define una política de respaldo: no hay programación, retención ni copia externa. El script SQL de carga inicial solo inicializa el contenedor. Sí se pudo respaldar y restaurar: pg_dump de la base en ejecución se cargó en una base temporal y los conteos coincidieron (3 usuarios, 20 pacientes, 0 exámenes, 0 documentos, 6 registros de auditoría y 3 roles). Esa base temporal y el volcado se eliminaron después de la comparación.

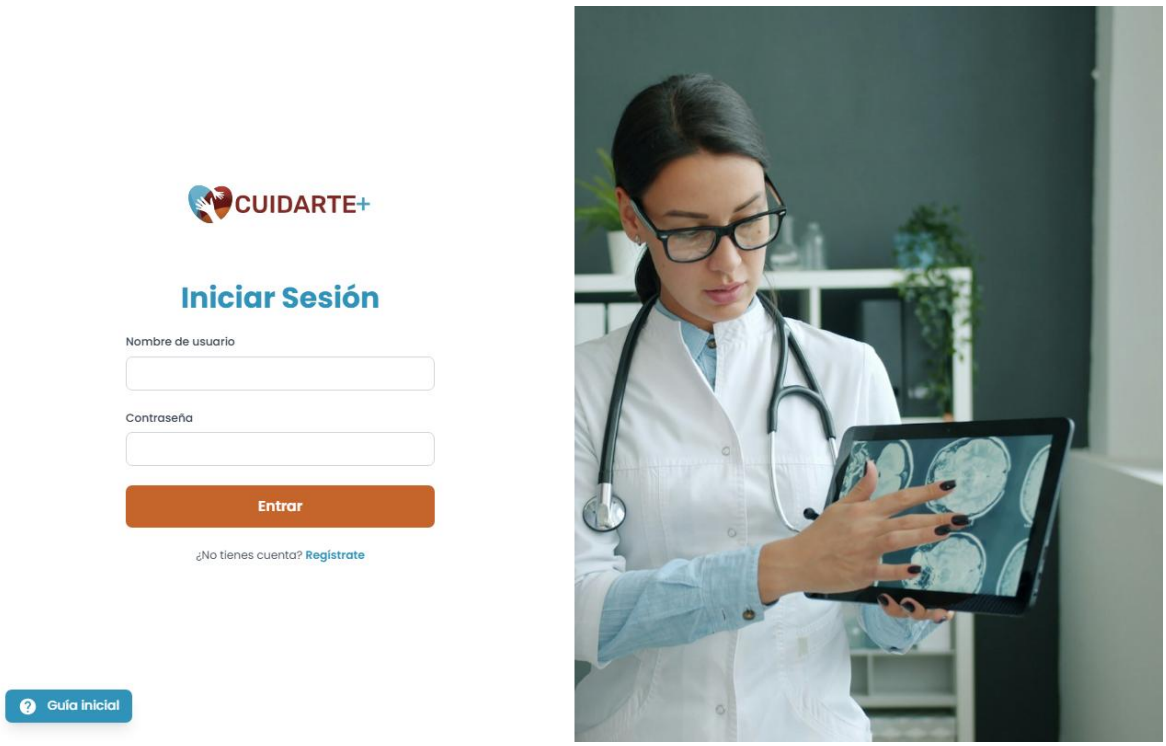
CP-06 falla frente a NFR-USAB-1, NFR-USAB-4 y NFR-COMPAT-2. Lighthouse, en la página de login, dio accesibilidad 0,96 y marcó contraste insuficiente en los controles Entrar, Regístrate y Guía inicial. Medido en pantalla, el texto blanco del botón queda en 3,98:1 y el mensaje de error en 3,76:1, bajo el 4,5:1 de texto normal. Las etiquetas miden 12,25 px y los campos 14 px, pequeños para una persona mayor. En una ventana de 390 px el panel de login sigue al 50 % del ancho, el título se parte en dos líneas y la fotografía ocupa la otra mitad. El menú interno sí tiene versión móvil. El médico ve Pacientes y Exámenes al mismo nivel, sin un paso que obligue a abrir al paciente antes del examen. INC-12 no se reejecutó: hay 0 exámenes y 0 documentos, y el código actual descarga el archivo en lugar de abrir un selector. No se hizo la prueba de usabilidad con cinco usuarios que pide el ERS (§3.1.1), por lo que este resultado se apoya en Lighthouse y en la medición directa.

CP-20 falla frente a NFR-USAB-3. Los errores de formulario sí se entienden: al enviar el login vacío aparecen «El nombre de usuario es requerido» y «La contraseña es requerida», y una credencial incorrecta responde «Credenciales inválidas» (HTTP 401). La ayuda no está junto a los campos clínicos: en el login hay un diálogo de guía inicial y, ya con sesión,

una página /ayuda. INC-06 no se reprodujo en este recorrido de login. El mensaje interno sí queda confirmado en el código y se registra en CP-17.

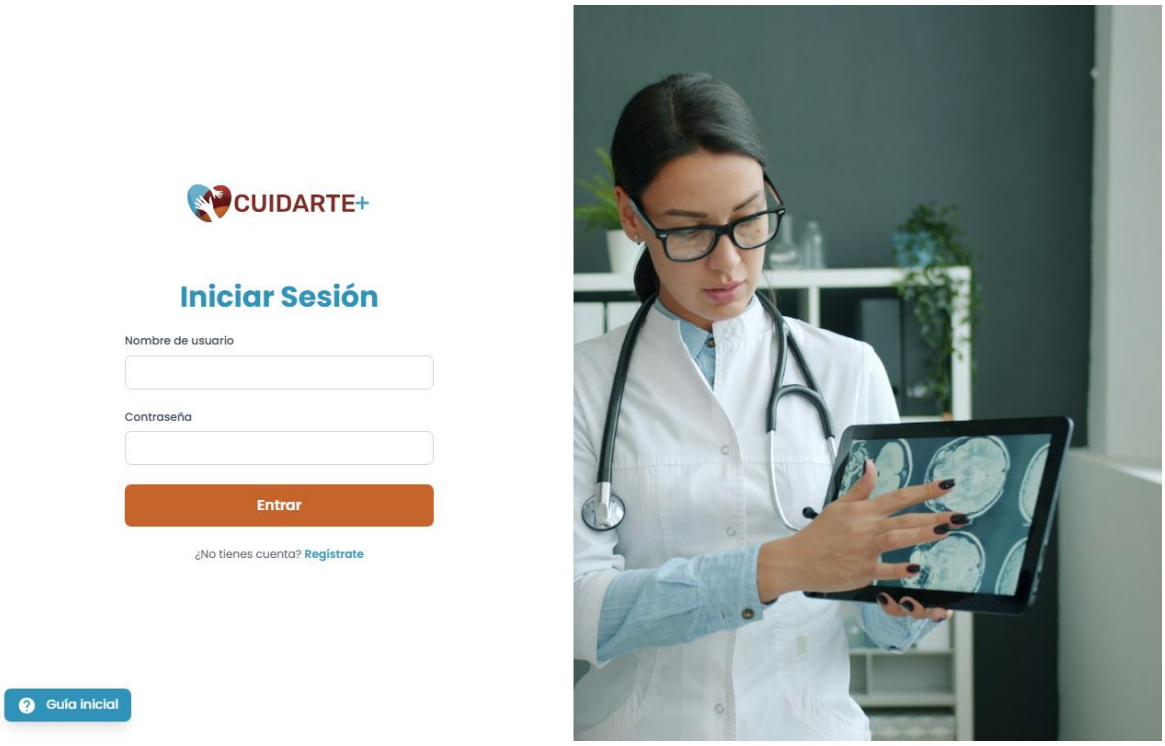
CP-22 queda parcial. Chrome 155.0.8059.81 y Edge 155.0.4283.45 muestran el mismo login, en escritorio y en 390 px de ancho. Firefox y Safari no están instalados en este equipo, y tampoco se probó la versión anterior de cada navegador, que es lo que pide NFR-COMPAT-1. Por eso el caso no se cuenta como aprobado ni como fallido.

**Figura 1. Login de Cuidarte+ en Chrome 155 (CP-22)**



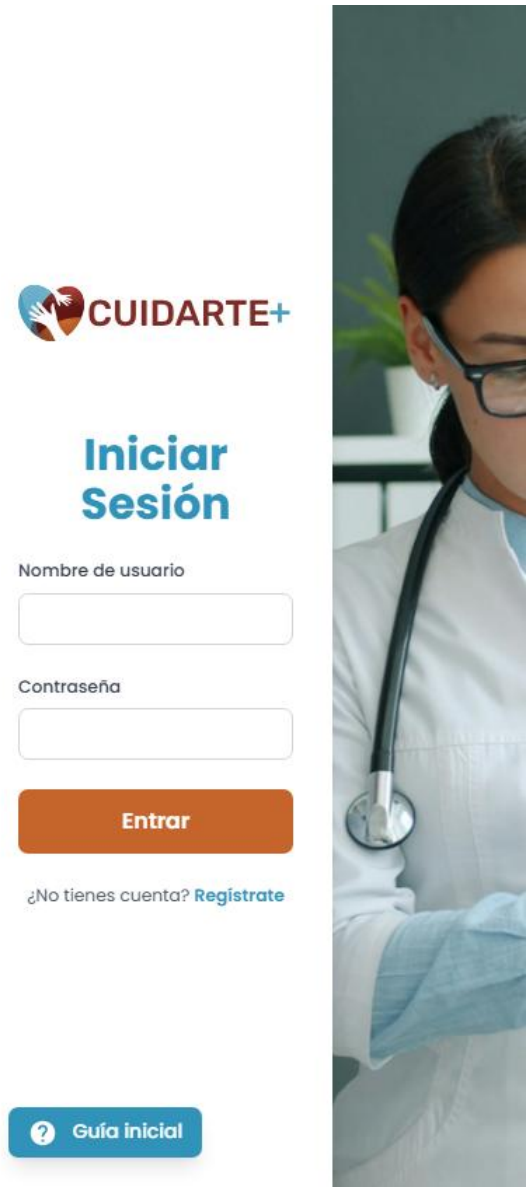

*Nota.* Captura de Skarlett Tropan, 20 de octubre de 2026.

**Figura 2.** **Login de Cuidarte+ en Edge 155 (CP-22), igual al de Chrome**




*Nota.* Captura de Skarlett Tropan, 20 de octubre de 2026.

**Figura 3. Login en Chrome con ventana de 390 px (CP-06); el formulario ocupa la mitad del ancho**




*Nota.* Captura de Skarlett Tropan, 20 de octubre de 2026.

CP-04 queda parcial. El 26 de octubre Ari Araya corrió OWASP ZAP 2.17.0 con sesión, importando la definición OpenAPI de la API y agregando el token de médico y después el de paciente en cada petición. El escaneo terminó con 0 alertas altas, 2 medias y 4 bajas. El reporte no se exportó, así que el detalle de esas alertas no queda en la evidencia. Durante el escaneo, POST /documentos respondió 500 con los dos tokens. Nikto no se usó y las cabeceras se revisaron con curl. La API responde Access-Control-Allow-Origin con asterisco y X-Powered-By: Express, y no envía CSP, X-Frame-Options, X-Content-Type-Options ni HSTS. Con eso INC-05 queda confirmado en CORS y cabeceras. El límite de intentos de login no se probó.

Burp Suite tampoco se usó. El control de acceso se probó con Swagger y curl, cambiando el token y el identificador en cada petición. Con token de paciente, GET /pacientes/2, DELETE /pacientes/1, DELETE /examenes/10 y POST /examenes con un cuerpo válido responden 403. El paciente 1 recibe 200 al pedir sus propios exámenes y 403 al pedir los del paciente 2, mientras que el médico recibe 200. Sin token la respuesta es 401 «Token inválido». Esta parte cumple RB-1, aunque la prueba no llamó a /roles, así que INC-07 sigue sin ejecutarse. Si el cuerpo de la petición es inválido, la API responde 400 antes de revisar el rol, porque la validación corre primero.

**Figura 4. Respuestas de la API con token de paciente (CP-04): exámenes propios 200 y del paciente 2, 403**

```
PS C:\windows\system32> curl.exe -i http://localhost:4444/examenes/paciente/1 -H "Authorization: Bearer $pac"
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 2
ETag: W/"2-l9Fw4VUO7kr8CvBlt4zaMCqXZ0w"
Date: Tue, 27 Oct 2026 01:39:52 GMT
Connection: keep-alive
Keep-Alive: timeout=5

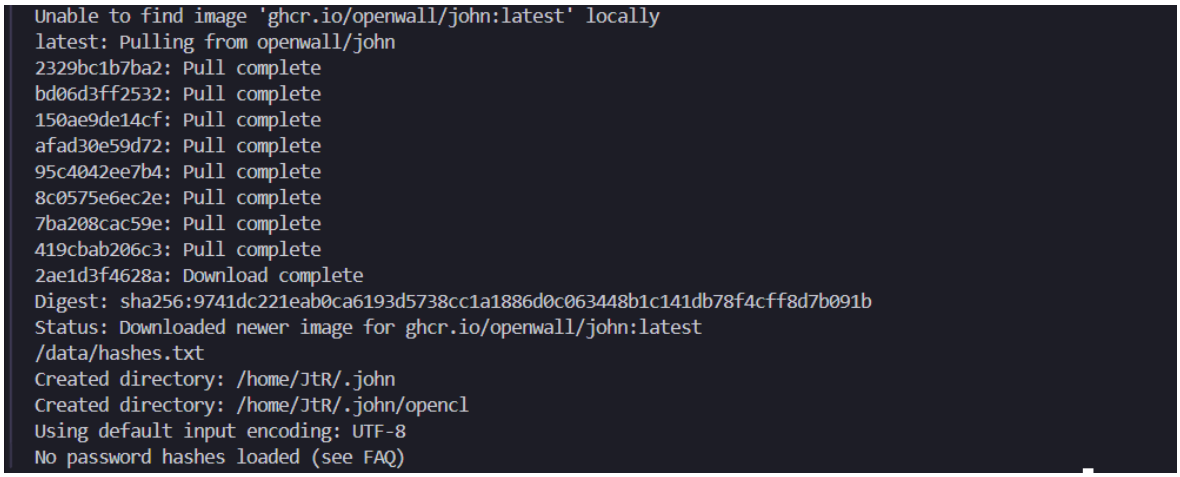
[]
PS C:\windows\system32> curl.exe -i http://localhost:4444/examenes/paciente/2 -H "Authorization: Bearer $pac"
HTTP/1.1 403 Forbidden
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 72
ETag: W/"48-h1dOSO2kwzzQEO+dRy6jnqclEAM"
Date: Tue, 27 Oct 2026 01:40:57 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"error":"No autorizado","glosa":"Solo puede ver sus propios exámenes"}
PS C:\windows\system32>
```

*Nota.* Captura de Ari Araya, 26 de octubre de 2026.

CP-15 falla y confirma INC-01. En la base, la columna contrasena de la tabla usuarios es de tipo text y guarda las claves admin, medico y paciente sin hash, iguales al nombre de cada usuario. El login con esas claves responde 200. John the Ripper, ejecutado desde su imagen oficial de Docker, respondió «No password hashes loaded», porque no hay ningún hash que romper. La contraseña queda a la vista de cualquiera que lea la base.

**Figura 5. John the Ripper sin hashes que cargar desde la base de prueba (CP-15)**

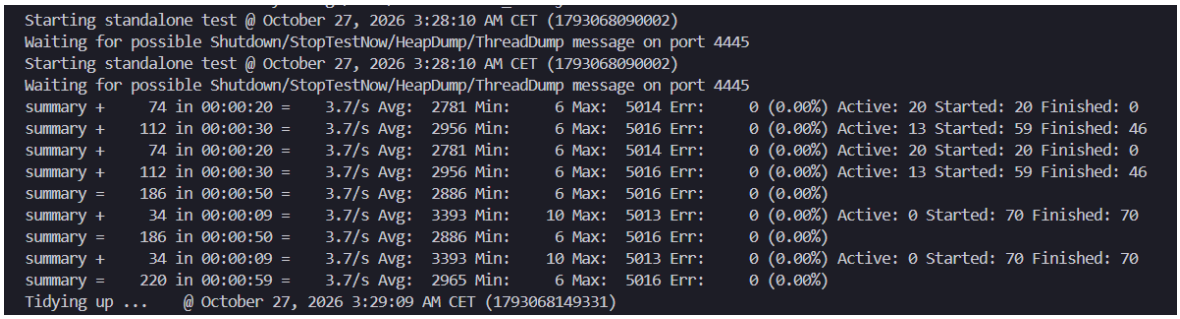



*Nota.* Captura de Ari Araya, 26 de octubre de 2026.

CP-17 falla frente a NFR-SEG-6. El 20 de octubre SonarQube no marcó *Security Hotspots*Security Hotspots ni detectó los mensajes internos que el backend devuelve al cliente, y el detalle del escáner está en la sección 5.4. El 27 de octubre Skarlett Tropan revisó el código de main y encontró el mismo patrón en 34 bloques catch de ocho rutas. Cada uno escribe el error completo con console.error y le responde al cliente un campo glosa con err.message. El log de acceso usa morgan en formato dev, sin redacción. Con eso INC-06 queda confirmado en el código, aunque falta la captura del cuerpo de un 500, porque el que apareció el 26 de octubre en POST /documentos no se guardó. Ese mismo día Ari Araya probó con Swagger y curl la parte que el plan le asignaba a Burp Suite, y los 401 y 403 usaron mensajes genéricos. INC-14 ya estaba confirmado en CP-03, donde un médico escribió en la auditoría con POST /auditoria y recibió 201. INC-11 sigue sin ejecutar al 27 de octubre de 2026, porque no se corrió npm audit.

CP-05 falla y confirma INC-04. Con el plan de JMeter de la EV1 y el retraso activo, 70 usuarios virtuales generaron 220 muestras en 59 segundos, con 3,7 peticiones por segundo, promedio de 2965 ms, máximo de 5016 ms y 0 % de error. El login responde en unos 13 ms, mientras que las consultas de pacientes y exámenes promedian entre 5008 y 5011 ms, muy lejos de los 300 ms que pide el ERS. La corrida sin el retraso no se hizo, así que el tiempo real del CRUD sigue sin medirse. CP-19 tampoco se ejecutó, por lo que no hay medición de Lighthouse sobre la página principal ni prueba con 200 usuarios.

**Figura 6. Resumen de JMeter con el retraso activo (CP-05): 220 muestras, promedio de 2965 ms y 0 % de error**




*Nota.* Captura de Ari Araya, 26 de octubre de 2026.

CP-21 falla. Es una revisión documental del despliegue en Docker y de la configuración de nginx. Los tres contenedores levantan y quedan *healthy*, pero cada servicio tiene una sola réplica, reinicio unless-stopped, un healthcheck sin start_period y solo HTTP en el puerto 80. No hay respaldo automático, ventana de mantenimiento ni una medición que permita demostrar el 99,5 % mensual. Se registra como INC-17, moderado, porque NFR-DIS-1 y NFR-DIS-2 no se pueden demostrar con este despliegue.

## 5.3 Criticidad de incidentes

Adaptamos la escala de criticidad al contexto de Cuidarte+. Como el sistema guarda datos de salud, la exposición de información clínica o de credenciales se considera crítica aunque el sistema siga funcionando.

**Tabla 25. Escala de criticidad**

| Nivel | Descripción en Cuidarte+ | Impacto | Acción requerida |
|---|---|---|---|
| **CRÍTICO** | Expone datos clínicos o credenciales, permite suplantar usuarios o impide usar una función esencial (login, consulta de exámenes) | Muy alto: compromete la confidencialidad o la continuidad de la atención y el cumplimiento legal | Remediación inmediata; bloquea la certificación |
| **GRAVE** | Afecta un control de seguridad o una función importante, pero existe una forma de seguir operando | Alto: debilita el acceso, la sesión, la trazabilidad o la conservación de la ficha | Corrección urgente con plan y fecha |
| **MODERADO** | Afecta funciones secundarias o el endurecimiento del sistema sin detener el flujo principal | Medio: el usuario trabaja con molestias o el riesgo depende de otra falla | Se corrige en la próxima iteración |
| **LEVE** | Defecto de apariencia, texto o desviación menor del ERS sin efecto en la operación ni en los datos | Bajo: no impacta la operación | Se corrige según disponibilidad |

La tabla siguiente lista los incidentes que la revisión del código del repositorio (commit 7503d1b) hace esperar, con la severidad que proponemos y lo que mostró la ejecución del 20 y del 26 de octubre de 2026 y la revisión del código del 27 de octubre de 2026. Los incidentes que no se ejecutaron se mantienen porque la lectura del código los sostiene.

**Tabla 26. Incidentes y criticidad**

| Incidente | Caso | Descripción | Resultado | Impacto propuesto |
|---|---|---|---|---|
| **PRUEBAS FUNCIONALES Y DE INTEGRACIÓN** | | | | |
| INC-09 | CP-08, CP-11 | Borrado físico (DELETE FROM) de exámenes, documentos, pacientes y usuarios; el ERS pide baja lógica | Confirmado en el código (27 oct, Skarlett). DELETE FROM en usuarios, pacientes, exámenes y documentos; el de usuarios borra antes de leer el token. CP-08 y CP-11 no incluyeron eliminación | **GRAVE** |
| INC-12 | CP-06, CP-13 | El botón Ver Documento no muestra el adjunto (HALL-01 de la EV1) | No confirmado. CP-06 (20 oct) sin documentos de prueba en la base | **MODERADO** |
| INC-13 | CP-03 | La descarga de documentos no deja registro en la auditoría | Confirmado en CP-03 | **GRAVE** |
| INC-15 | CP-13 | El filtro de carga acepta solo PDF, JPG y PNG; el ERS pide además DOC y PPT | Confirmado en CP-13 | **MODERADO** |
| INC-16 | CP-13, CP-16 | Archivo guardado en una columna bytea y carpeta de documentos subidos publicada sin autenticación | Confirmado en CP-13 y CP-16. Un archivo de prueba en /files/documentos respondió 200 sin token | **GRAVE** |
| **PRUEBAS DE SEGURIDAD** | | | | |
| INC-01 | CP-01, CP-15 | Contraseñas guardadas y comparadas en texto plano; usuarios semilla con contraseña igual al nombre | Confirmado en CP-15 (26 oct) | **CRÍTICO** |
| INC-02 | CP-01 | Secreto JWT por defecto "inseguro" y secreto real publicado en el README y en el .env versionado | Confirmado en el código (27 oct, Skarlett). Valor «inseguro» en siete rutas y otro secreto por defecto en docker-compose. Sin prueba dinámica | **GRAVE** |
| INC-03 | CP-07 | No existe logout ni revocación; el token dura 2 horas | Confirmado en CP-07 | **GRAVE** |
| INC-05 | CP-04 | CORS abierto, sin cabeceras de seguridad ni límite de intentos de login | Confirmado en CP-04 (CORS y cabeceras). Límite de intentos sin probar | **MODERADO** |
| INC-06 | CP-17, CP-20 | Los errores 500 devuelven el mensaje interno al cliente | Confirmado en el código en CP-17 (27 oct). 34 bloques catch devuelven err.message. No se reprodujo en CP-20 y el cuerpo del 500 no quedó guardado | **MODERADO** |
| INC-07 | CP-08 | /roles permite crear, editar y borrar roles sin pedir token | Confirmado en el código (27 oct, Skarlett). Ninguna operación de /roles valida el token, que solo se lee para la auditoría. Sin prueba dinámica | **GRAVE** |
| INC-08 | CP-04 | Token guardado en localStorage, expuesto ante un XSS | Confirmado en el código (27 oct, Skarlett). El contexto de autenticación del frontend guarda el token en localStorage. Sin prueba dinámica | **MODERADO** |
| INC-10 | CP-09 | Contraseña mínima de 6 caracteres; el ERS exige 12 con complejidad | Parcial. Mínimo de 8 en el cambio de clave (CP-09) y de 6 en el código de /registro, sin probar. Los dos quedan bajo los 12 del ERS | **MODERADO** |
| INC-11 | CP-17 | Dependencias con vulnerabilidades conocidas (npm audit en backend y frontend) | No ejecutado al 27 oct 2026. No se corrió npm audit y SonarQube no analiza dependencias | **GRAVE** |

| Incidente | Caso | Descripción | Resultado | Impacto propuesto |
|---|---|---|---|---|
| INC-14 | CP-03, CP-17 | POST /auditoria permite a cualquier usuario con token escribir registros | Confirmado en CP-03 (20 oct, médico con POST /auditoria, HTTP 201) y en la revisión de CP-17 | **GRAVE** |
| **PRUEBAS NO FUNCIONALES DE RENDIMIENTO Y DISPONIBILIDAD** | | | | |
| INC-04 | CP-05, CP-19 | delayMiddleware(5000) agrega 5 s a exámenes, pacientes y documentos | Confirmado con JMeter en la EV1<br>y en CP-05 (26 oct) | **GRAVE** |
| INC-17 | CP-21 | Una sola réplica, sin respaldo automático, ventana de mantenimiento ni medición de disponibilidad | Confirmado en CP-21 (26 oct) | **MODERADO** |

Además se registra la observación de cumplimiento OC-01, que no es un defecto del software sino de la regla RB-3 del ERS (sección 6.3). Mientras INC-01 siga abierto, el dictamen no puede ser Certificado.

Con la evidencia del 26 de octubre, INC-01 se mantiene como crítico, INC-04 como grave e INC-05 como moderado, y se agrega INC-17, moderado, por la disponibilidad que CP-21 no puede demostrar. En la revisión cruzada del 27 de octubre se subieron tres severidades respecto de la primera clasificación, y se adoptaron porque cada una tiene evidencia. INC-14 pasa de moderado a grave, porque CP-03 mostró que un médico puede escribir registros en la auditoría que el DS 41 art. 9 exige conservar. INC-16 pasa de moderado a grave, porque en CP-16 un archivo de prueba se descargó por /files/documentos sin token. INC-15 pasa de leve a moderado, porque el ERS pide DOC y PPT y CP-13 mostró que esos archivos no entran. La misma revisión precisó dos descripciones sin cambiar su severidad. INC-07 no pide token en ninguna operación de /roles, y el DELETE de usuarios de INC-09 borra antes de leer el token. La clasificación queda en 1 crítico, 9 graves y 7 moderados, sin incidentes leves. No se asignó un identificador BUG aparte, porque cada falla queda asociada a su incidente y a su caso.

## 5.4 Análisis estático con SonarQube

El análisis estático revisa el código fuente sin ejecutarlo. Se aplica por separado al backend y al frontend con SonarQube, y sus hallazgos se leen frente a OWASP Top 10 y a la normativa de la sección 6. La revisión manual del código que hicimos al preparar la matriz permite anticipar qué debería aparecer.

**Tabla 27. Resultados de SonarQube**

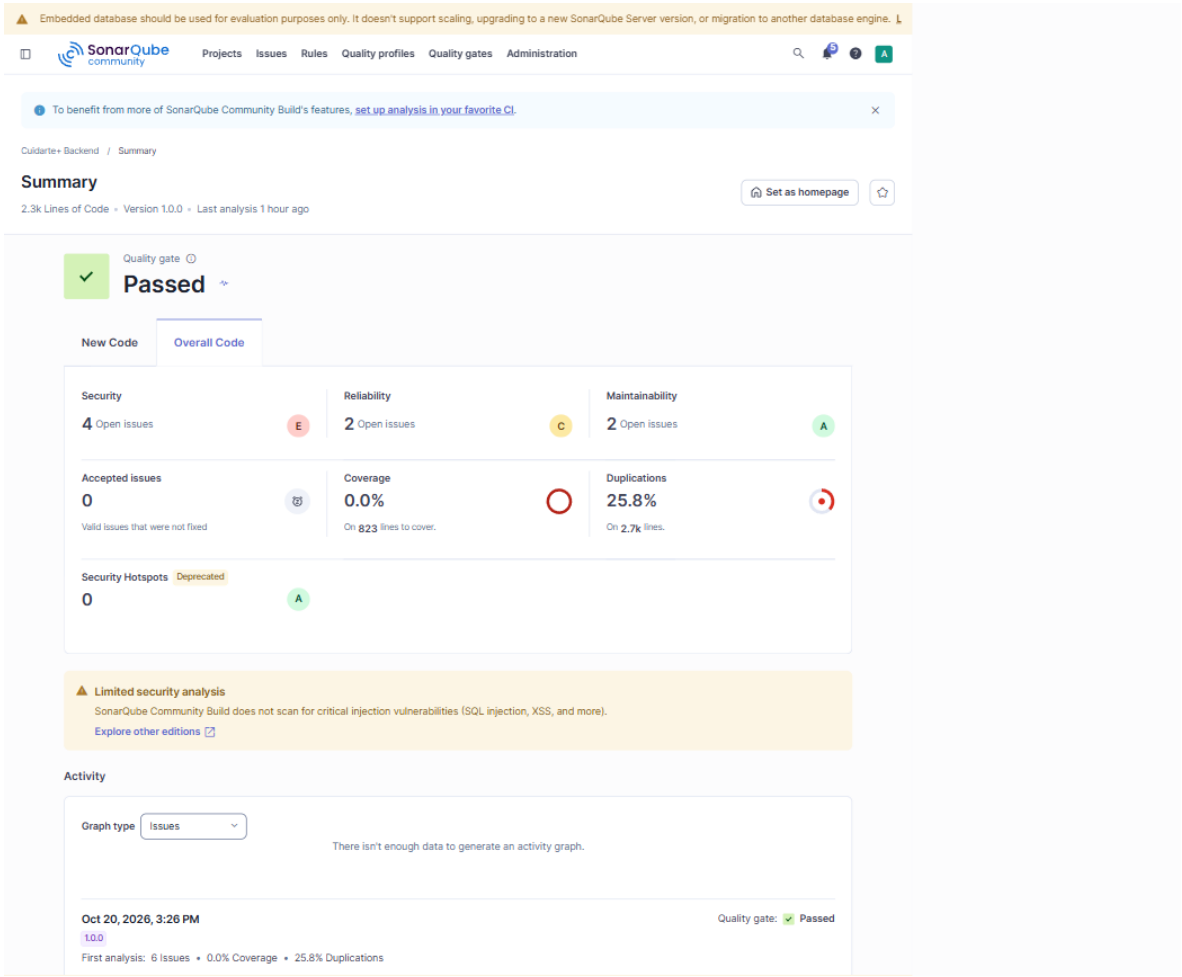
| Métrica | BACKEND | FRONTEND |
|---|---|---|
| *Quality Gate*Quality Gate | *Passed* | *Passed* |
| Bugs | 0 | 14 |
| Vulnerabilidades | 4 | 0 |
| *Security Hotspots*Security Hotspots | 0 (métrica obsoleta en esta versión) | 0 (métrica obsoleta en esta versión) |

| Métrica | BACKEND | FRONTEND |
|---|---|---|
| Code Smells | 2 | 3 |
| Duplicación (%) | 25,8 % | 7,8 % |
| Cobertura de pruebas | 0,0 %. No hay pruebas unitarias. | 0,0 %. No hay pruebas unitarias. |

El análisis se ejecutó el 20 de octubre de 2026 en SonarQube Community Build 26.10.0.133078, en modo MQR, sobre el código fuente del backend y del frontend. Las capturas muestran *Overall Code*Overall Code. El Quality Gate figura *Passed*: en esta versión la puerta mide el código nuevo, y el primer análisis del código heredado puede aprobarla con hallazgos en el total. La nota de seguridad del backend, sobre el código total, es E.

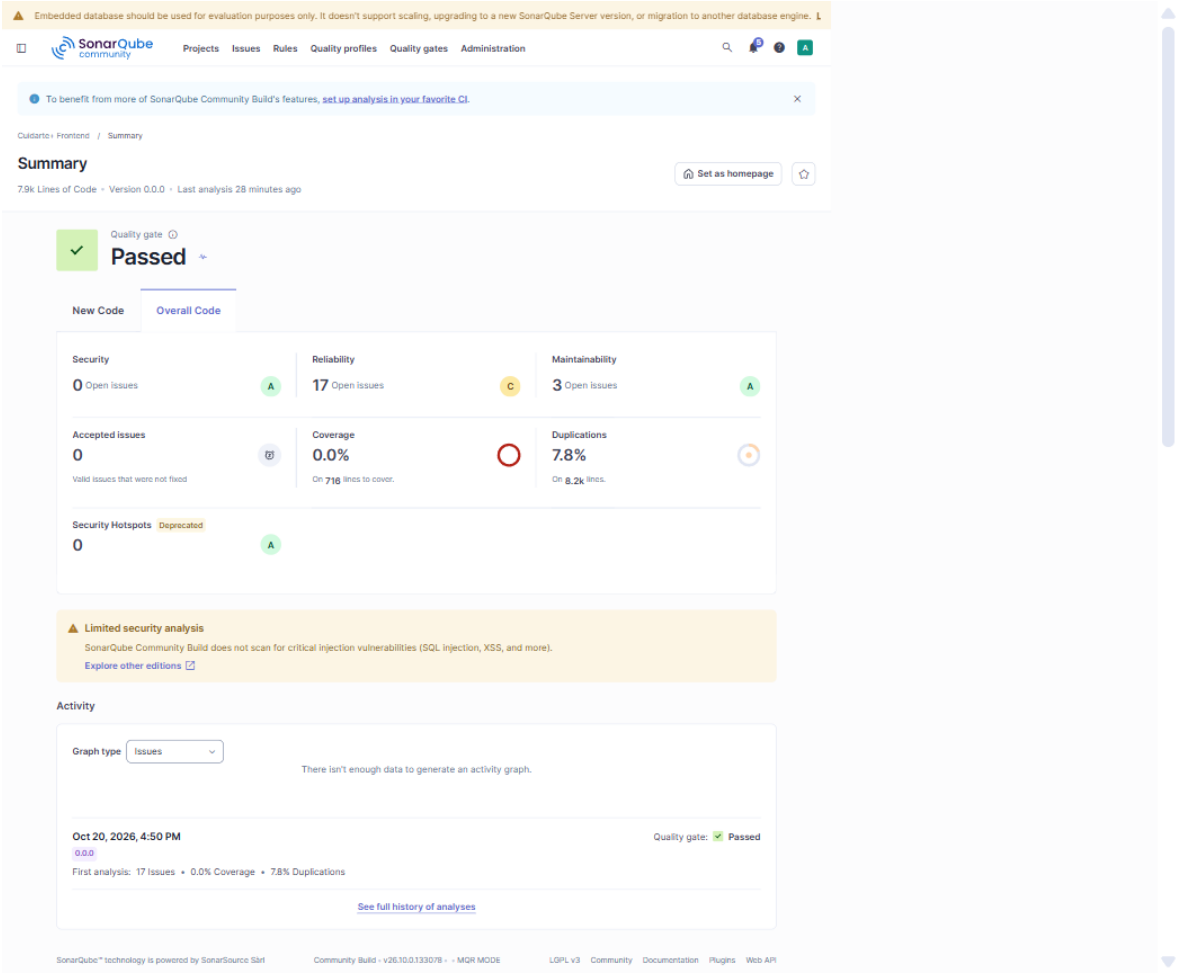
La pantalla *Summary* agrupa por cualidad del software: *Security*, *Reliability* y *Maintainability*. La Tabla 27 conserva los tipos clásicos que entrega el análisis. En el backend hay 4 vulnerabilidades y 2 code smells; en la captura, *Security* muestra esos 4 y *Reliability* y *Maintainability* muestran los mismos 2 code smells. En el frontend hay 14 bugs y 3 code smells, 17 *issues* en total; la captura los reúne en *Reliability* (17) y vuelve a contar los 3 smells en *Maintainability*. Community Build no analiza inyección SQL ni XSS, y esta ejecución omitió el análisis de dependencias. La cobertura 0,0 % corresponde a la ausencia de pruebas unitarias en el repositorio.

**Figura 7.** **SonarQube, Cuidarte+ Backend, *SummaryOverall Code* en Overall Code**




*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 8.** **SonarQube, Cuidarte+ Frontend, *SummaryOverall Code* en Overall Code**




*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Tabla 28.** **Hallazgos estáticos esperados y su lectura legal**

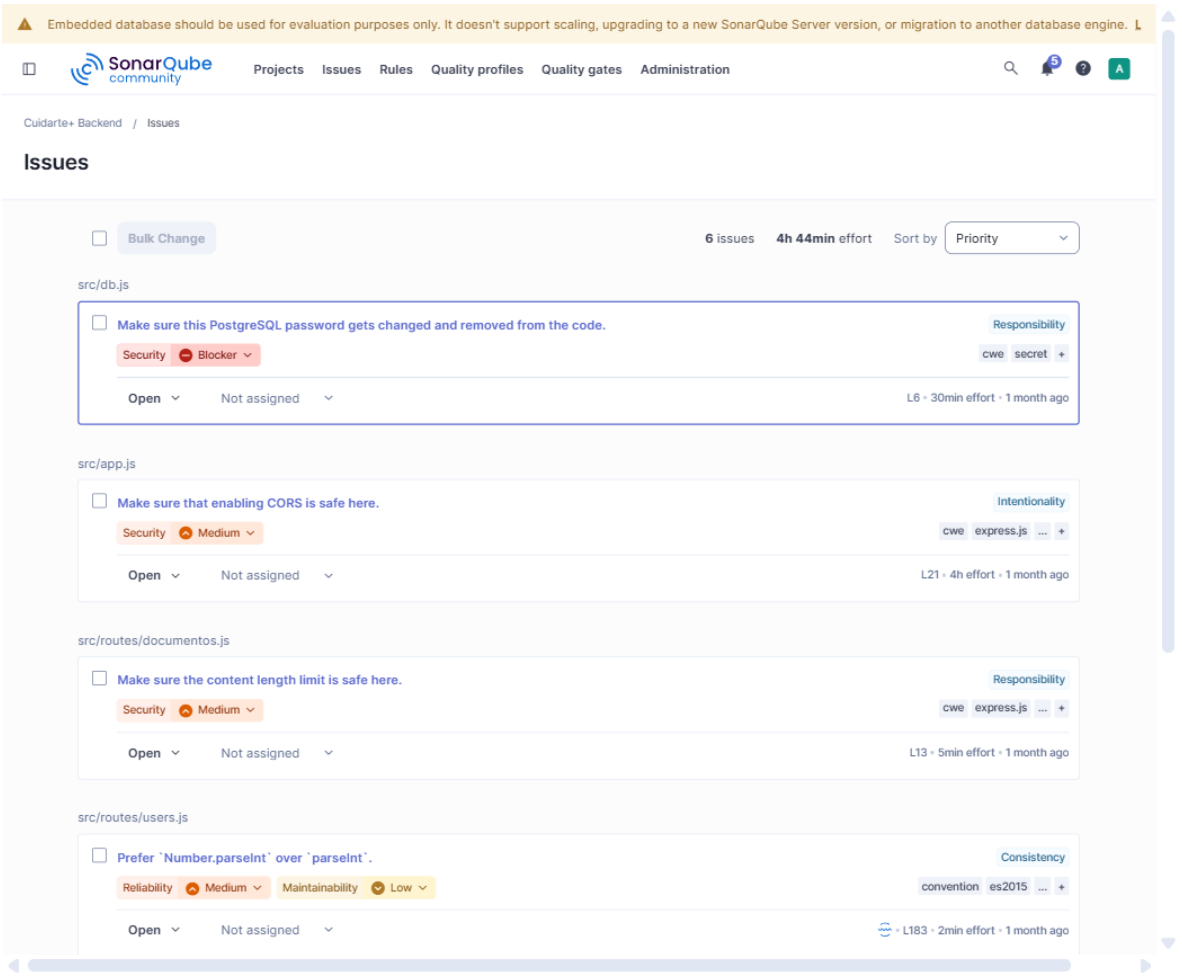
| Hallazgo esperado | Ubicación | Categoría OWASP | Norma relacionada |
|---|---|---|---|
| Secreto escrito en el código ("inseguro") | routes/*.js (7 archivos) | Fallas criptográficas y de autenticación | Ley 19.628 art. 11; DS 41 art. 9 |
| Comparación de contraseña en texto plano | routes/auth.js/auth.js, líneas 21 y 110 | Fallas criptográficas y de autenticación | Ley 19.628 art. 11; Ley 20.584 art. 12 |
| Mensajes de error internos enviados al cliente | routes/*.js (bloques catch) | Configuración de seguridad incorrecta | NFR-SEG-6; Ley 19.628 art. 11 |
| CORS permisivo | app.jsapp.js, línea 21 | Configuración de seguridad incorrecta | DS 41 art. 8 |
| Token en localStorage | context/AuthContext.jscontext/AuthContext.jsx | Fallas de autenticación | DS 41 art. 8 |
| Dependencias vulnerables | package.jspackage.json de ambos módulos | Componentes vulnerables y desactualizados | Ley 19.628 art. 11; Ley 17.336 arts. 78 y 79 |

La Tabla 28 se contrastó con los *issues* que el escáner marcó el 20 de octubre de 2026. El secreto «inseguro» de JWT, repetido en siete rutas como valor por defecto, no fue marcado. Sí se marcó un secreto del mismo tipo: la contraseña de PostgreSQL escrita en el módulo

de conexión a la base, con severidad *Blocker*. Se lee con la Ley 19.628 art. 11 y el DS 41 art. 9. La comparación de contraseña en texto plano del login (Tabla 28) no fue detectada; sigue abierta como INC-01 por la revisión manual del código. Los mensajes de error internos enviados al cliente tampoco fueron detectados. El CORS permisivo de la configuración de la API (Tabla 28) quedó confirmado (*SecurityMedium*, Medium) y se mantiene la lectura del DS 41 art. 8. El token guardado en localStorage por el contexto de autenticación del frontend no fue marcado: el frontend cerró con 0 vulnerabilidades, y el hallazgo se sostiene por la lectura del código. Las dependencias vulnerables no se evaluaron, porque el escáner informó que el análisis de dependencias fue omitido.

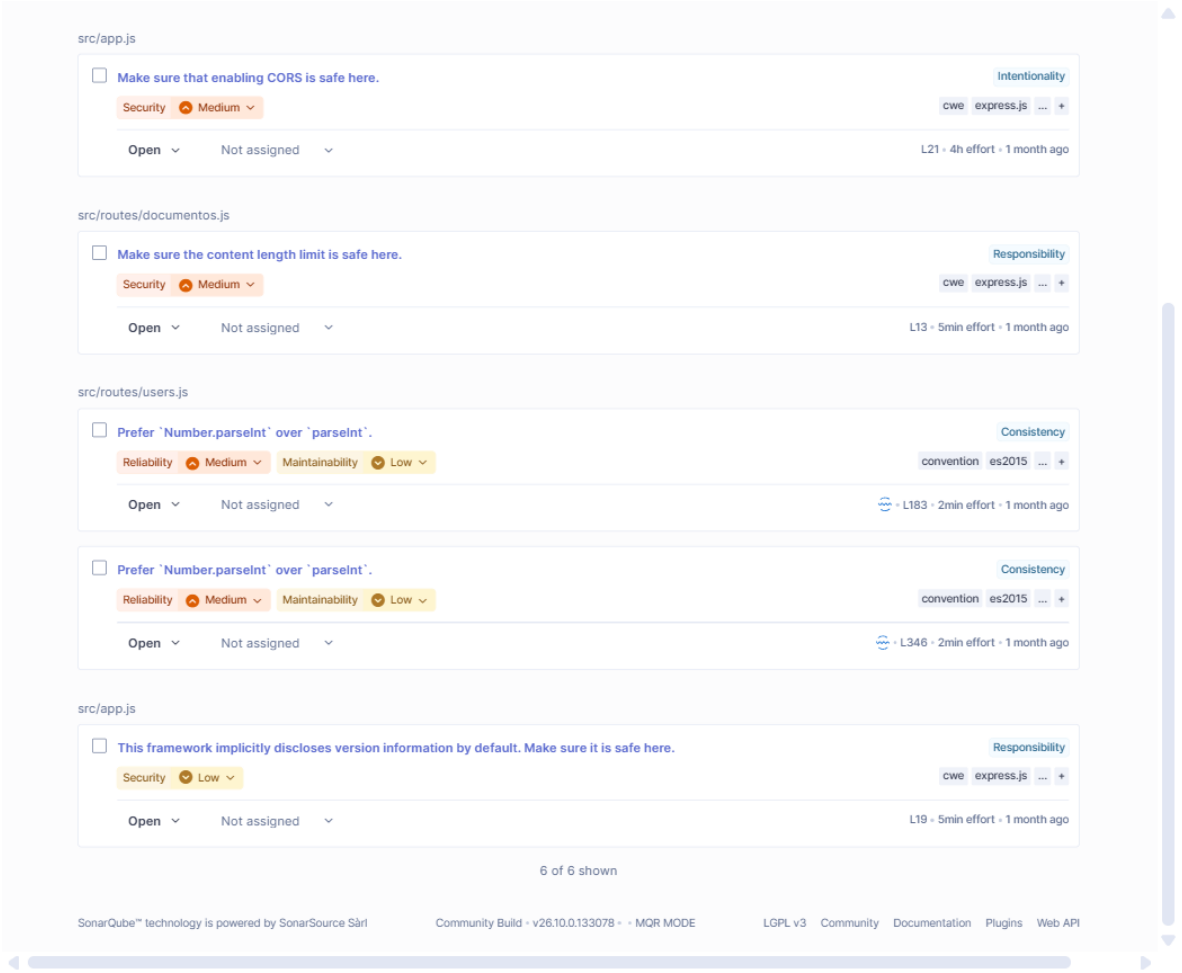
Las figuras 9 a 16 documentan el listado de *issues*. En el frontend el ancho del panel recorta el final de algunos títulos largos; en cada tarjeta se leen el archivo y la severidad, y la última figura cierra el listado en 17 de 17.

**Figura 9. Issues de Cuidarte+ Backend, primera parte del listado**



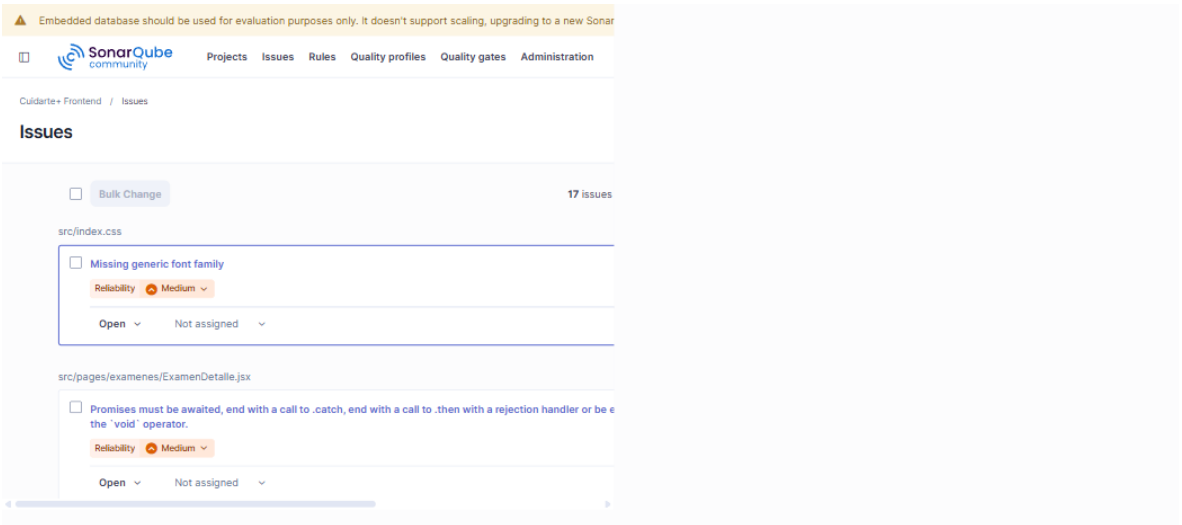

*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 10. Issues de Cuidarte+ Backend, continuación hasta 6 de 6**



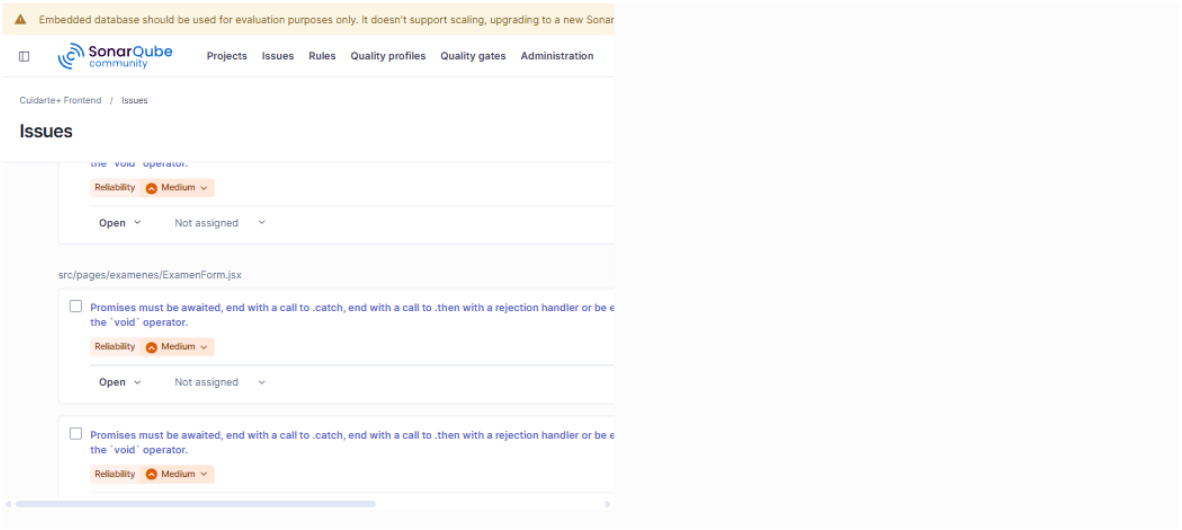

*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 11. Issues de Cuidarte+ Frontend, parte 1 de 6**



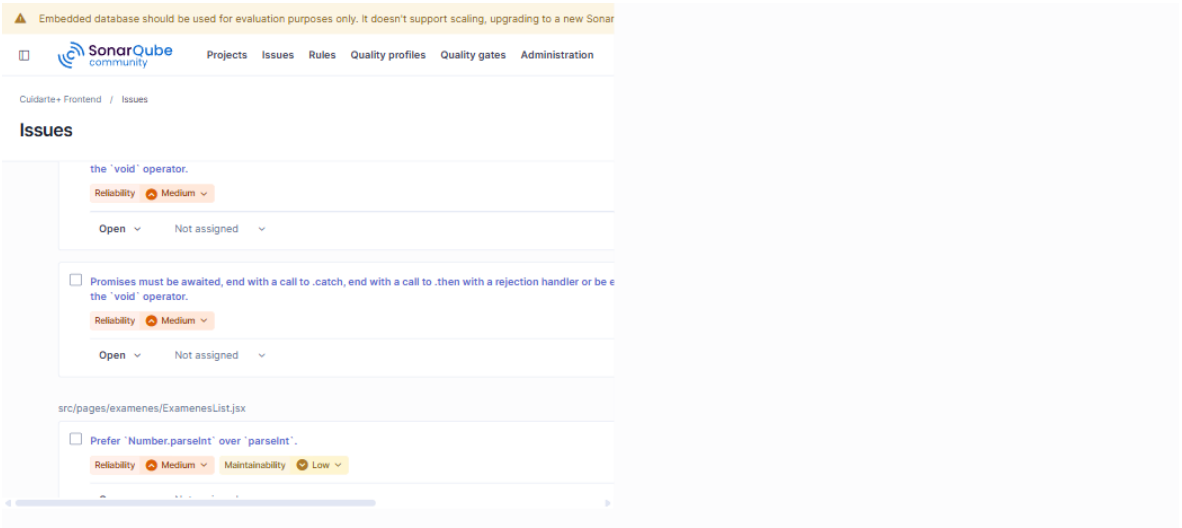

*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 12. Issues de Cuidarte+ Frontend, parte 2 de 6**



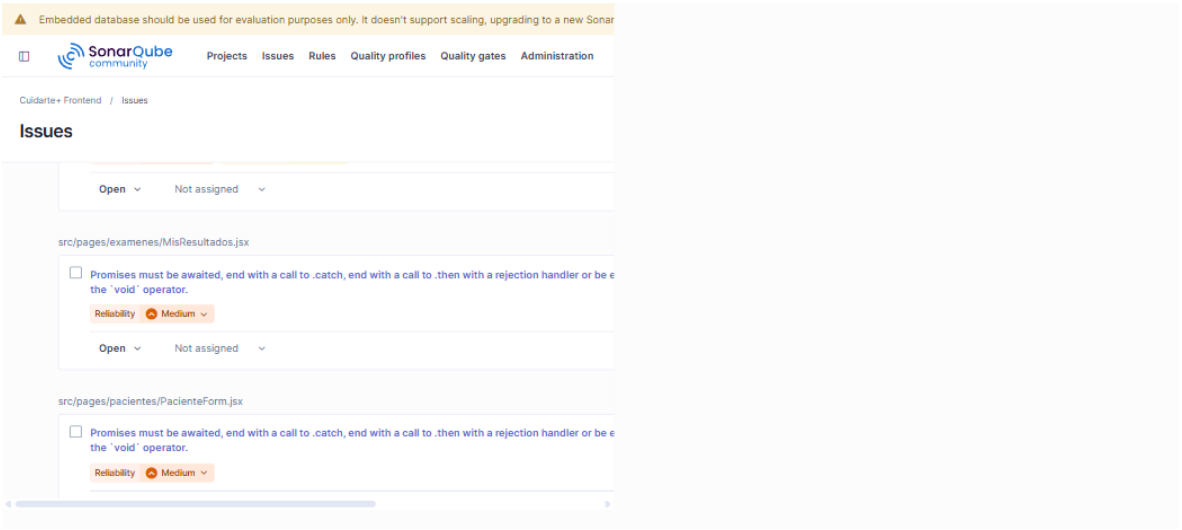

*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 13. Issues de Cuidarte+ Frontend, parte 3 de 6**




*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 14. Issues de Cuidarte+ Frontend, parte 4 de 6**




*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 15. Issues de Cuidarte+ Frontend, parte 5 de 6**




*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

**Figura 16. Issues de Cuidarte+ Frontend, parte 6 de 6, cierre en 17 de 17**




*Nota.* Captura de SonarQube Community Build tomada por Skarlett Tropan, 20 de octubre de 2026.

# 6. Análisis ético y normativo de los resultados

## 6.1 Enfoque

En la EV1 construimos el marco legal casi por completo desde la protección de datos y la ciberseguridad. En la revisión de la EV1 el docente nos indicó que faltaba la normativa propia del caso, en particular la ley de derechos de los pacientes y lo relativo a la atención de urgencia, y que había información con discordancias. Cuidarte+ guarda exámenes y documentos clínicos, así que la primera norma que lo regula es la que establece los derechos de los pacientes y las reglas de la ficha clínica.

Esta versión pone la normativa sanitaria en el centro (Ley 20.584, su modificación por la Ley 21.668 y el reglamento de fichas clínicas, DS 41 de 2012 del MINSAL), separa lo vigente de lo que entra en vigencia en diciembre de 2026 y corrige las citas de la EV1 que no correspondían (Anexo A).

La mayoría de estas leyes no obligan al software, sino a quien lo usa para tratar datos o atender pacientes, que en este caso es el centro de salud que opere Cuidarte+. CreaLab, como desarrollador, queda obligado de forma indirecta: si entrega un sistema que no permite cumplir la ley, el prestador tampoco podrá cumplirla. Por eso cada norma termina en una exigencia que se puede verificar con un caso de la matriz.

## 6.2 Marco normativo aplicable

La vigencia de cada norma se revisó al 19 de octubre de 2026 en los textos publicados en LeyChile y en las copias entregadas en el curso.

**Tabla 29. Marco normativo aplicado a Cuidarte+**

| Norma | Estado | Artículos considerados | Exigencia y caso que la verifica |
|---|---|---|---|
| Ley 20.584, derechos y deberes de las personas en su atención de salud | Vigente | Art. 5 a) y 5° bis (información comprensible y atención preferente a mayores de 60 años); art. 10 (información al paciente, con regla para urgencias); art. 12 (ficha clínica en soporte electrónico, autenticidad de los cambios; datos de exámenes como sensibles); art. 13 (conservación de al menos 15 años, acceso solo de quienes participan en la atención, copia al titular); art. 15 b) (urgencia sin consentimiento) | Acceso restringido: CP-04, CP-10 y OC-01. Autenticidad de los cambios: CP-03 y CP-11. Copia al titular: CP-12 y CP-13. Conservación: CP-11 |
| Ley 21.668, interoperabilidad de fichas clínicas (modifica los arts. 12 y 13 de la Ley 20.584) | Vigente desde el 28 may 2024 | Nuevo texto de los arts. 12 y 13; art. tercero transitorio (actualización del reglamento) | Sin estándar técnico publicado que probar; queda como recomendación de diseño |
| DS 41 de 2012, MINSAL, reglamento sobre fichas clínicas | Vigente | Art. 8 (respaldo, barreras ante accesos no autorizados, restauración); art. 9 (acceso controlado y registro de quién accedió y cuándo); art. 11 (conservación de 15 años); art. 12 (eliminación con acta) | Registro de lecturas y descargas: CP-03. Respaldo: CP-18. Barreras de acceso: CP-04 y CP-14. Eliminación controlada: CP-11 |
| Ley 19.628, protección de la vida privada | Vigente (texto actual hasta el 30 nov 2026) | Art. 2 g) (datos sensibles, incluye estados de salud); art. 7 (secreto); art. 10 (tratamiento de datos sensibles); art. 11 (cuidado con la debida diligencia); art. 23 (indemnización) | Base actual de la responsabilidad por INC-01 e INC-02: CP-01 y CP-15 |
| Ley 21.719, protección y tratamiento de datos personales | Publicada el 13 dic 2024; vigente desde el 1 dic 2026 | Nuevo texto de la Ley 19.628: art. 3 (principios); art. 14 quinquies (medidas de seguridad); art. 14 sexies (reporte de vulneraciones); art. 16 bis (datos de salud); arts. 34 ter, 34 quáter y 35 (infracciones y multas) | Se cita como norma de vigencia próxima. Cifrado en reposo: CP-16. Restauración: CP-18 |
| Ley 21.663, Ley Marco de Ciberseguridad | Vigente | Art. 4 (la prestación institucional de salud es servicio esencial); art. 9 (alerta temprana al CSIRT en tres horas); art. 27 (incidente de efecto significativo) | La obligada es la institución. El sistema debe dejar registros útiles para reportar a tiempo: CP-03 y CP-17 |
| DFL 1 de 2005, MINSAL, arts. 141 y 173 (atención de urgencia, origen en la Ley 19.650) | Vigente | Prohíbe exigir garantías de pago o condicionar la atención de urgencia | Cuidarte+ no gestiona pagos ni admisión, por lo que no aplica en forma directa. Sí importa el acceso oportuno a exámenes en una urgencia: CP-05, CP-19 y CP-21 |
| Ley 21.459, delitos informáticos | Vigente | Arts. 1 a 4 (ataque a la integridad, acceso ilícito, interceptación, ataque a los datos) | Explica el impacto de cada falla de acceso y limita nuestras pruebas al ambiente local |
| Ley 17.336, propiedad intelectual | Vigente | Arts. 78 y 79 | Revisión de licencias de dependencias junto con npm audit (INC-11) |
| Manual de Accesibilidad Web del Gobierno de Chile | Guía técnica | Criterios alineados con WCAG; se complementa con la Ley 20.584 arts. 5 a) y 5° bis | CP-06 y CP-20 |

El Código Sanitario figuraba en la EV1 como texto suelto, sin artículos y con referencias a farmacias y sustancias que no corresponden al caso, por lo que se retiró. La Ley 19.799 y el Decreto 181 solo aplican si los informes se firman electrónicamente, lo que el ERS no pide, y la Ley 21.180 solo si el sistema interopera con organismos públicos.

### 6.3 Tensión entre el ERS y la ley

Al cruzar el ERS con la Ley 20.584 encontramos un punto que no vimos en la EV1. La regla RB-3 dice que un médico puede ver la información clínica de cualquier paciente registrado. El artículo 13 de la Ley 20.584 dispone que quienes no estén directamente relacionados con la atención no tendrán acceso a la ficha, incluido el personal de salud del mismo prestador que no participa en esa atención, y el artículo 9 del DS 41 agrega que el acceso debe ser controlado y registrado. RB-2 tiene un problema parecido, porque entrega acceso completo a un administrador que no participa en la atención.

Como equipo de QA no podemos cambiar el ERS, pero sí informarlo. RB-3 se prueba tal como está escrita y, en paralelo, se registra como observación de cumplimiento OC-01. Una alternativa sería limitar el acceso del médico a los pacientes que atiende y habilitar un acceso de emergencia justificado y registrado para las urgencias, en línea con el artículo 15 b) de la misma ley. Es una propuesta para conversar con el cliente, no una exigencia del ERS actual.

### 6.4 Hallazgos y deber legal afectado

**Tabla 30. Incidentes y deber legal afectado**

| Incidente | Hallazgo | Norma afectada |
|---|---|---|
| INC-01 | Contraseñas en texto plano | Ley 19.628 art. 11; Ley 20.584 art. 12; DS 41 art. 8. Desde el 1 dic 2026, art. 14 quinquies |
| INC-02 | Secreto JWT por defecto y publicado | Ley 20.584 art. 13; DS 41 art. 9; facilita la conducta del art. 2 de la Ley 21.459 |
| INC-03 | Sin logout ni revocación | Ley 20.584 art. 13; DS 41 art. 9 |
| INC-04 | Retraso artificial de 5 s | Ley 20.584 arts. 12 y 13 (acceso oportuno); DS 41 art. 8 |
| INC-07 | /roles sin token ni control de rol | Ley 20.584 art. 13; DS 41 art. 9 |
| INC-09 | Borrado físico de información clínica | Ley 20.584 art. 13 (15 años); DS 41 arts. 11 y 12 |
| INC-11 | Dependencias vulnerables | Ley 19.628 art. 11; Ley 17.336 arts. 78 y 79 |
| INC-13 | Descarga sin auditoría | DS 41 art. 9; RF-5.1 |
| INC-14 | Auditoría escribible desde el cliente | DS 41 art. 9; Ley 21.663 art. 9 |
| INC-16 | Documentos sin cifrar y publicados por una ruta sin token | Ley 19.628 art. 11; Ley 20.584 art. 13; DS 41 art. 8; RF-4.4 |
| INC-17 | Disponibilidad y mantenimiento no demostrables | Ley 20.584 arts. 12 y 13 (acceso oportuno); DS 41 art. 8 |

| Incidente | Hallazgo | Norma afectada |
|---|---|---|
| INC-05, 06, 08, 10, 12, 15 | Endurecimiento, mensajes de error, sesión en el navegador, política de contraseñas y manejo de documentos | DS 41 art. 8; Ley 19.628 art. 11; Ley 20.584 art. 13 a); RF-4.3 y RF-4.4 |
| Sin ID (CP-14) | Sin TLS en frontend, API ni base de datos | DS 41 art. 8; Ley 19.628 art. 11. Desde el 1 dic 2026, art. 14 quinquies |
| Sin ID (CP-18) | Sin política de respaldo, retención ni copia externa | DS 41 art. 8. Desde el 1 dic 2026, art. 14 quinquies |
| Sin ID (SonarQube) | Contraseña de PostgreSQL escrita en el código del backend | Ley 19.628 art. 11; DS 41 art. 9 |

Sobre INC-09 tomamos una decisión distinta a la de la EV1. El borrado físico no bloquea el uso del sistema, pero una ficha clínica eliminada sin acta antes de 15 años no se puede recuperar y deja al prestador fuera de los artículos 11 y 12 del DS 41; por eso lo clasificamos como grave. También informamos los controles que sí funcionan: el login usa consultas parametrizadas, /usuarios rechaza con 403 a un paciente, la API le rechaza con 403 las escrituras y los datos de otros pacientes, la descarga limita al paciente a sus propios documentos y la carga de archivos limita el tamaño a 10 MB.

La Tabla 30 se armó con la revisión del código. Ahora se contrasta con la ejecución del 20 y del 26 de octubre y con la revisión de CP-17 del 27 de octubre de 2026. Nueve incidentes quedaron confirmados en la ejecución. Son INC-03 en CP-07, INC-13 e INC-14 en CP-03, INC-15 en CP-13, INC-16 en CP-13 y CP-16, INC-01 en CP-15, INC-04 en CP-05, INC-05 en CP-04 e INC-17, nuevo, en CP-21. INC-06 no se reprodujo en CP-20, pero CP-17 lo confirmó en el código, con 34 bloques catch que le devuelven err.message al cliente. INC-12 no se pudo repetir en CP-06 porque la base no tenía documentos, así que tampoco se da por confirmado. En CP-09 la clave corta se rechazó con un mínimo de 8 caracteres en el cambio de contraseña, y el /registro, donde el código valida 6, no se probó. INC-10 queda parcial, porque los dos mínimos están bajo los 12 que pide el ERS.

INC-02, INC-07, INC-08 e INC-09 no tienen prueba dinámica a la fecha de este informe, pero la revisión cruzada del 27 de octubre los confirmó en el código. El valor «inseguro» del secreto JWT está en siete rutas y docker-compose trae otro secreto por defecto. Ninguna operación de /roles revisa el token, que solo se lee para escribir la auditoría. El token del navegador se guarda en localStorage y las eliminaciones usan DELETE FROM. INC-07 e INC-09 no se vieron en CP-08 y CP-11, porque esa ejecución no incluyó la edición de roles ni la revisión del borrado en la base, y la prueba de control de acceso del 26 de octubre tampoco llamó a /roles. INC-11 sigue sin ejecutar al 27 de octubre de 2026, porque no se corrió npm audit. INC-01, además de quedar confirmado en CP-15, tiene el antecedente de la EV1 (HALL-02).

La ejecución y SonarQube agregaron tres hallazgos sin incidente previo, que van al final de la tabla. CP-14 mostró que ni el frontend, ni la API, ni PostgreSQL usan TLS. CP-18 mostró que el respaldo se puede hacer de forma manual, pero no hay una política con programación, retención ni copia externa. SonarQube marcó como *Blocker* la contraseña de PostgreSQL escrita en el código del backend y anticipó el CORS permisivo de INC-05, que CP-04 confirmó después. Estos tres hallazgos se informan con el caso que los detectó y no tienen identificador propio. La disponibilidad que CP-21 no pudo demostrar sí quedó registrada como INC-17.

### 6.5 Lectura ética

La parte legal indica qué se puede sancionar. La parte ética parte de algo más simple: en Cuidarte+ las personas afectadas son pacientes, muchos de ellos adultos mayores, y un examen filtrado no se puede deshacer. Con esa idea definimos cuatro criterios de trabajo.

El primero es usar solo datos sintéticos, sin RUT ni datos reales, aunque el ambiente sea local. El segundo es reportar todo lo encontrado, incluido lo incómodo, como la tensión de RB-3 con la Ley 20.584; ocultar un hallazgo para que el informe se vea mejor sería faltar a la responsabilidad que asumimos como equipo de calidad. El tercero es no probar fuera del alcance: OWASP ZAP, SQLMap, John the Ripper, JMeter y curl se usaron solo contra nuestra instalación en Docker, porque usarlos contra un sistema ajeno sin autorización es la conducta que sanciona la Ley 21.459. El cuarto es no minimizar el impacto en las personas mayores: un mensaje técnico como el de INC-06, o un login con bajo contraste y etiquetas pequeñas como el que mostró CP-06, puede dejar a un paciente sin acceso a sus resultados, lo que afecta un derecho que la Ley 20.584 le reconoce.

### 6.6 Dictamen

**Dictamen:** NO CERTIFICADO.

El dictamen sigue los criterios de certificación de la sección 3.3. Para certificar se necesita que no haya incidentes críticos abiertos, que todos los casos P0 estén aprobados y que los 40 códigos del ERS tengan resultado de ejecución. Al cierre de este informe, el 27 de octubre de 2026, no se cumple ninguna de las tres condiciones.

El dictamen se apoya en tres incidentes. El primero es INC-01, el único crítico, que CP-15 confirmó el 26 de octubre, porque las contraseñas se guardan y se comparan en texto plano. Le siguen dos graves que salen de la revisión del código. INC-02 es el secreto JWT por defecto, publicado además en el README y en el .env versionado, por lo que quien lo lea puede firmar un token válido. INC-07 es la ruta /roles, que deja crear, editar y borrar roles sin pedir token. Ninguno de los dos tiene todavía prueba dinámica, pero la revisión del 27 de

octubre confirmó el defecto en el código, y ese defecto choca con el art. 13 de la Ley 20.584 y el art. 9 del DS 41.

A eso se suman cuatro casos P0 fallidos. CP-15 falla por INC-01, CP-07 porque el token sigue vigente después de cerrar sesión (INC-03), CP-14 porque no hay TLS y CP-16 porque los datos clínicos y los documentos no están cifrados. CP-03, que es P1, también falla porque la descarga de documentos no queda auditada (INC-13), justo lo que el DS 41 art. 9 le exige al prestador. CP-17, también P1, falla porque los errores 500 le devuelven al cliente el mensaje interno (INC-06). De los 40 códigos, 38 tienen resultado (10 aprobados, 10 parciales y 18 fallidos). Faltan NFR-PERF-2 y NFR-PERF-3, porque CP-19 no se ejecutó.

Lo que falta ejecutar no puede cambiar el dictamen, porque el crítico confirmado y las fallas P0 bastan para no certificar. Sí puede cambiar el plan de corrección. Para llegar a Certificado con reservas habría que cerrar INC-01, INC-02 e INC-07, lograr que pasen los cuatro P0, lo que exige cerrar INC-03 y habilitar TLS y cifrado en reposo, ejecutar CP-19 y la corrida de CP-05 sin el retraso, y presentar un plan con fechas para los graves que queden abiertos, en especial INC-04 e INC-13.

### 6.7 Recomendaciones

Las recomendaciones se ordenan por prioridad. La prioridad usa la escala de riesgo de la sección 3.1 (P0 a P4), y cada recomendación indica el incidente o caso que la origina y, cuando corresponde, la norma que la respalda.

6. **P0. Hash de contraseñas con bcrypt. Aplicarlo en el registro y en el login, cambiar las contraseñas semilla y exigir 12 caracteres con complejidad (INC-01, INC-10). Base: Ley 19.628 art. 11 y ERS §2.4.**
7. **P0. Rotación del secreto JWT y cierre de sesión con revocación. Sacar el secreto del README y del .env versionado, rotarlo e invalidar el token en el servidor al cerrar sesión (INC-02, INC-03, RF-1.2). Base: Ley 19.628 art. 11.**
8. **P0. Control de rol en /roles. Exigir token y rol de administrador en todas las operaciones de /roles y revisar el resto de las rutas de administración (INC-07). Base: Ley 20.584 art. 13.**
9. **P0. Autenticación en la ruta de documentos. Proteger /files/documentos con token y guardar los archivos en almacenamiento interno con referencia en la base, como pide RF-4.4 (INC-16). Base: DS 41 art. 8.**
10. **P0. TLS en todas las capas. Habilitar HTTPS con redirección desde HTTP, HSTS y ssl en PostgreSQL (CP-14, NFR-SEG-1). Base: DS 41 art. 8.**

11. **P0. CORS y cabeceras de seguridad. Restringir CORS a los orígenes del frontend, agregar CSP, X-Frame-Options y X-Content-Type-Options, quitar X-Powered-By y limitar los intentos de login (INC-05, CP-04). Base: DS 41 art. 8.**
12. **P0. Token fuera de localStorage. Guardar la sesión en una cookie HttpOnly con SameSite, junto con la CSP de la recomendación anterior (INC-08). Base: DS 41 art. 8.**
13. **P0. Revisión de RB-3 y RB-2 con el cliente. Limitar el acceso del médico a sus pacientes y dejar registrado el acceso de emergencia (OC-01). Base: Ley 20.584 arts. 13 y 15 b).**
14. **P0. Cifrado en reposo. Cifrar los datos clínicos y los documentos almacenados (CP-16, NFR-SEG-3). Base: Ley 19.628 art. 11 y, desde el 1 de diciembre de 2026, Ley 21.719 art. 14 quinquies.**
15. **P1. Auditoría de lecturas y descargas. Registrar quién, cuándo y qué recurso en cada lectura y descarga, y cerrar POST /auditoria a los clientes (INC-13, INC-14). Base: DS 41 art. 9.**
16. **P1. Baja lógica. Reemplazar el borrado físico por baja lógica, con conservación por 15 años y eliminación con acta (INC-09). Base: Ley 20.584 art. 13 y DS 41 arts. 11 y 12.**
17. **P1. Errores genéricos. Mostrar mensajes genéricos al usuario y dejar el detalle técnico solo en los registros del servidor (INC-06, NFR-SEG-6). Base: Ley 19.628 art. 11. Esos registros son los que el centro necesitaría para reportar a tiempo si queda sujeto al art. 9 de la Ley 21.663.**
18. **P1. Política de respaldo y reporte de vulneraciones. Definir programación, retención, copia externa y prueba periódica de restauración, junto con un procedimiento para reportar vulneraciones (CP-18, NFR-SEG-7). Base: DS 41 art. 8 y Ley 21.719 art. 14 sexies.**
19. **P1. Dependencias y licencias. Ejecutar npm audit en el backend y en el frontend, actualizar lo vulnerable y revisar las licencias (INC-11). Base: Ley 17.336 arts. 78 y 79.**
20. **P2. Formatos de documento. Aceptar DOC y PPT o corregir el ERS, y mostrar un mensaje cuando se rechaza un archivo (INC-15, RF-4.3).**
21. **P3. Retraso artificial. Quitar el retraso de 5 s, volver a medir CP-05 sin él y ejecutar CP-19 (INC-04).**
22. **P3. Disponibilidad. Definir réplica, healthcheck con tiempo de arranque y ventana de mantenimiento, y medir la disponibilidad mensual (INC-17, NFR-DIS-1 y NFR-DIS-2).**

23. **P4. Accesibilidad del login. Subir el contraste a 4,5:1 como mínimo, agrandar etiquetas y campos y adaptar el login a pantallas angostas (CP-06, CP-20, NFR-USAB-1 y NFR-USAB-4). Base: Ley 20.584 arts. 5 a) y 5° bis.**

## 7. Conclusiones

Con la matriz reconstruida, el diseño de pruebas de Cuidarte+ cubre el 100 % de los requisitos del ERS B, frente a 14 de 40 (35 %) en la EV1. La ejecución del ciclo 2 muestra que el sistema no está listo para producción: guarda contraseñas en texto plano, no revoca el token al cerrar sesión, no audita las descargas de documentos clínicos y, según la revisión del código, borra en forma física información que la ley obliga a conservar.

El cambio más importante respecto de la EV1 está en la lectura normativa. Al poner la Ley 20.584 y el reglamento de fichas clínicas en el centro, varios hallazgos que antes parecían solo técnicos pasan a ser incumplimientos concretos para el centro de salud, y aparece una tensión en el propio ERS (RB-3) que conviene resolver con el cliente antes de corregir el código.

La ejecución del 20 y del 26 de octubre de 2026, junto con la revisión del código del 27 de octubre, confirmó buena parte de lo que anticipaba la revisión del código. De los 23 casos se ejecutaron 22. Siete se aprobaron, doce fallaron y tres quedaron parciales. Los flujos funcionales responden bien. El login, el registro de exámenes y la gestión de pacientes funcionan, el paciente ve solo sus propios exámenes y la API le rechaza con 403 cualquier escritura o dato ajeno. Las fallas se concentran en controles que no son visibles para el usuario. Las contraseñas se guardan en texto plano, el token sigue vivo después del cierre de sesión, la descarga de documentos no queda auditada y cualquier usuario con token puede escribir en la auditoría, y los errores del servidor le devuelven al cliente el mensaje interno. Tampoco hay TLS, los datos clínicos no están cifrados, no existe una política de respaldo y la API responde con CORS abierto y sin cabeceras de seguridad. Con el retraso activo, las consultas tardan alrededor de 5 s.

SonarQube aportó un hallazgo que no estaba en nuestra lista, la contraseña de PostgreSQL escrita en el código, y confirmó el CORS permisivo. También dejó ver sus límites. No detectó la comparación de contraseñas en texto plano ni el secreto JWT por defecto, y la cobertura quedó en 0 % porque el repositorio no tiene pruebas unitarias. Por eso el análisis estático no reemplaza a la revisión manual ni a las pruebas dinámicas.

El dictamen es No certificado y se sostiene en INC-01, el crítico que CP-15 confirmó el 26 de octubre, y en los graves INC-02 e INC-07, que están en el código y todavía esperan su prueba dinámica. Además cuatro casos P0 fallaron y dos códigos del ERS siguen sin resultado. Falta ejecutar CP-19, medir CP-05 sin el retraso y probar en ejecución INC-02 e

INC-07, junto con corregir esos tres incidentes, que son los que más exponen la ficha clínica frente a la Ley 19.628, la Ley 20.584 y el DS 41. La Ley 21.719 entra en vigencia el 1 de diciembre de 2026 y exige al responsable adoptar medidas de seguridad (art. 14 quinquies) y reportar las vulneraciones (art. 14 sexies). Para datos de salud, el cifrado en reposo y una política de respaldo son medidas esperables, por lo que conviene resolverlos antes de esa fecha.

## 8. Referencias

Decreto 41 de 2012 [Ministerio de Salud]. *Aprueba reglamento sobre fichas clínicas*. 15 de diciembre de 2012. https://www.bcn.cl/leychile/navegar?idNorma=1046753

Decreto con Fuerza de Ley 1 de 2005 [Ministerio de Salud]. *Fija texto refundido, coordinado y sistematizado del Decreto Ley N° 2.763, de 1979, y de las Leyes N° 18.933 y N° 18.469*. 24 de abril de 2006. https://www.bcn.cl/leychile/navegar?idNorma=249177

International Organization for Standardization. (2023). *Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — Product quality model* (ISO/IEC 25010:2023). https://www.iso.org/standard/78176.html

Ley 17.336 de 1970. *Propiedad intelectual*. 2 de octubre de 1970. https://www.bcn.cl/leychile/navegar?idNorma=28933

Ley 19.628 de 1999. *Sobre protección de la vida privada*. 28 de agosto de 1999. https://www.bcn.cl/leychile/navegar?idNorma=141599

Ley 20.584 de 2012. *Regula los derechos y deberes que tienen las personas en relación con acciones vinculadas a su atención en salud*. 24 de abril de 2012. https://www.bcn.cl/leychile/navegar?idNorma=1039348

Ley 21.459 de 2022. *Establece normas sobre delitos informáticos, deroga la Ley N° 19.223 y modifica otros cuerpos legales con el objeto de adecuarlos al Convenio de Budapest*. 20 de junio de 2022. https://www.bcn.cl/leychile/navegar?idNorma=1177743

Ley 21.663 de 2024. *Ley Marco de Ciberseguridad*. 8 de abril de 2024. https://www.bcn.cl/leychile/navegar?idNorma=1202434

Ley 21.668 de 2024. *Modifica la Ley N° 20.584, con el fin de establecer la interoperabilidad de las fichas clínicas*. 28 de mayo de 2024. https://www.bcn.cl/leychile/navegar?idNorma=1203827

Ley 21.719 de 2024. *Regula la protección y el tratamiento de los datos personales y crea la Agencia de Protección de Datos Personales*. 13 de diciembre de 2024. https://www.bcn.cl/leychile/navegar?idNorma=1209272

OWASP Foundation. (2021). *OWASP Top 10:2021*. https://owasp.org/Top10/2021/

World Wide Web Consortium. (2024). *Web Content Accessibility Guidelines (WCAG) 2.2*. https://www.w3.org/TR/WCAG22/

## Anexo A. Correcciones respecto de la EV1

Este informe retoma la primera evaluación con los ajustes surgidos de la retroalimentación del docente, que fue entregada de forma presencial. La tabla resume los cambios aplicados en este informe.

**Tabla 31. Correcciones aplicadas**

| N° | Dónde (EV1) | Antes | Ahora (EP3) | Sección |
|---|---|---|---|---|
| A1 | §5.1 Matriz | 11 filas, 14 de 40 códigos; 21 sin caso | 40 de 40 códigos con caso (CP-01 a CP-23) | 4.1 |
| A2 | §5.1 Cobertura | Se marcaba Cubierto con solo diseñar el caso | Se separan cobertura de diseño y resultado de ejecución | 3.3, 4.1, 5 |
| A3 | §5.2 Brechas | RF-2, RF-4.2, NFR-PERF-2 y 3, NFR-SEG-1 y 7, NFR-DIS-1 postergados | Cada uno con caso: CP-08 a CP-10, CP-13, CP-14, CP-18, CP-19 y CP-21 | 4.1, 4.2 |
| A4 | CP-03 | RF-5.1 probado solo con la eliminación | Se agregan la subida y la descarga de documentos | 4.3 |
| B1 | §2.3 Ley 19.628 | Se citaba el art. 22 y "derechos del paciente sobre su ficha" | Arts. 2 g), 7, 10, 11 y 23; los derechos sobre la ficha pasan a la Ley 20.584 | 6.2 |
| B2 | §2.3 texto suelto | Código Sanitario, Ley 20.584, decretos y normas técnicas sin artículos | Ley 20.584, Ley 21.668, DS 41 y urgencia (DFL 1) con artículos y casos; se retira el Código Sanitario | 6.2 |
| B3 | §2.3 Ley 21.719 | Tratada como vigente | Vigente desde el 1 dic 2026; hoy la base es la Ley 19.628 | 2.3, 6.2 |
| B4 | §2.3, §5.2 y §6 | "art. 35 de la Ley 21.719" | Art. 35 de la Ley 19.628 en el texto que introduce la Ley 21.719 | 6.2 |
| B5 | §2.3 Ley 21.663 | Art. 36 y "eleva el estándar de la plataforma" | Arts. 4, 9 y 27; la obligada es la institución de salud | 6.2 |
| B6 | §2.3 DS 181 y §6 | Título Cuarto del DS 181 como base de la integridad documental | La integridad se funda en la Ley 20.584 art. 12 y el DS 41 art. 8 | 2.3, 6.2 |
| B7 | §2.2 y CP-02 | RB-3 solo como requisito funcional | Se agrega la observación de cumplimiento OC-01 | 6.3 |
| C1 | Nombre del caso | El README del repositorio dice "Caso A" | Caso B: Sistema de exámenes médicos Cuidarte+ | Portada, 1.1 |
| D1 | §1.3 | Títulos de objetivos vacíos | Objetivo general y específicos redactados | 1.3 |
| D2 | §3.4 y §5.1 | Bloque "TIPOS DE PRUEBAS…" repetido | Eliminado; los tipos se desarrollan en 3.2 | 3.2 |
| D3 | §3.1, §3.4, CP-05 | Jest y k6 | Herramientas realmente usadas; JMeter para carga | 3.4 |

## Anexo B. Evidencias de la EV1 y del ciclo 2

Las evidencias de la EV1 están en la carpeta de entrega de la EV1 del repositorio y se citan como línea base en la sección 5.1. Las del ciclo 2 de la EP3 están en la carpeta de evidencias de cada integrante, y las principales se muestran como capturas en la sección 5.2.

**Tabla 32. Evidencias de la EV1 y del ciclo 2**

| Archivo | Contenido | Casos |
|---|---|---|
| Informe_Hallazgos_CuidartePlus.mdInforme_Hallazgos_CuidartePlus.md y .pdf | Hallazgos HALL-01 a HALL-05 y controles que funcionaron (7 y 8 de septiembre de 2026) | CP-01, 02, 04, 05, 06 |
| Informe_OWASP_ZAP_CuidartePlus.mdInforme_OWASP_ZAP_CuidartePlus.mdAnexos/OWASP_ZAP_ y Anexos/OWASP_ZAP_* | Escaneo baseline sin sesión del frontend y de la API (PDF, HTML y JSON) | CP-04 |
| Anexos/jmeter: CuidartePlus_CP05.jmxCuidartePlus_CP05.jmxresults_cp05.jtl, results_cp05.jtl y html_report | Plan y resultados de JMeter con el retraso activo | CP-05 |
| capturas-sonar, 10 imágenes | Summary e issues de SonarQube del backend y del frontend (Skarlett Tropan, 20 de octubre de 2026) | CP-16, CP-17 |
| capturas-ciclo2, 3 imágenes | Login en Chrome y Edge, y Chrome con 390 px de ancho (Skarlett Tropan, 20 de octubre de 2026) | CP-06, CP-22 |
| Evidencias de Nicolás Barra, carpetas CP-01 a CP-13 | Capturas de la interfaz y de Postman, salida de SQLMap y payloads manuales (20 de octubre de 2026) | CP-01 a 04, 07 a 13 |
| Evidencias/CP-01Evidencias/CP-01selenium-login-medico.png de Nicolás Barra: selenium-smoke-output.txtselenium-login-medico.png y selenium-smoke-output.txt | Suite de Selenium con pytest y Page Objects ejecutada el 27 de octubre de 2026, con 11 de 11 pruebas aprobadas, reporte HTML y JSON y una captura por prueba. La prueba de humo previa registró «[OK] Login medico -> http://localhost:3333/home» | CP-01 |
| Bitácora y documento de pruebas de Ari Araya | Ejecución del 26 de octubre de 2026 con ZAP, curl, John the Ripper y JMeter, con el archivo de resultados de CP-05 | CP-04, 05, 15, 17, 21 |
| Revisión de CP-17 de Skarlett Tropan | Revisión del código de main del 27 de octubre de 2026, con los 34 bloques catch | CP-17 |